



Cyber Security

SERVICIO DE ETHICAL HACKING A LOS SISTEMAS DE CANALES DIGITALES

Para:



INFORME TÉCNICO BANCA MÓVIL

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales CAJA MAYNAS	Código: EH-CMACMYS- IT
		Versión: 2.0
	INFORME TÉCNICO BANCA MÓVIL	Fecha: 02/04/2025
		Página: 2 de 132

Historial de Versiones

Fecha	Versión	Descripción	Autor
02/04/2025	1.0	Elaboración del plan de gestión de proyecto	Omar Palomino
02/04/2025	2.0	Actualización del documento	Omar Palomino

Revisado y Aprobado por:

Nombre	Rol
Omar Palomino	Gerente del Proyecto KUNAK

CONTENIDO

Introducción	5
1. ALCANCE.....	5
2. METODOLOGÍA DE EXPLOTACIÓN	6
3. METODOLOGÍA DE CUANTIFICACIÓN DE LAS VULNERABILIDADES (CVSS).....	9
4. RESUMEN DE LA PRUEBA REALIZADA	10
5. DETALLE DE LAS PRUEBAS REALIZADAS	11
RESULTADOS DE ETHICAL HACKING – ANDROID Y iOS	11
5.1. Inadecuada gestión de acceso: Acceso a saldos y movimientos de otras cuentas ...	11
5.2. Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta	15
5.3. Ausencia de la verificación de Integridad del Binario.....	21
5.4. Bypass del código de verificación SMS	24
5.5. Inadecuado cifrado a nivel de la capa de aplicación.....	29
5.6. Configuración errónea en el archivo Info.plist.....	32
5.7. Almacenamiento de información de sesión en texto claro.....	35
5.8. Falta de Ofuscación de claves de API y datos sensibles en binario.....	40
5.9. Falta de Protección contra Depuración	43
5.10. Exposición de archivos de configuración sensibles	46
5.11. Inadecuado proceso de time out	50
5.12. Inyección de Código en Tiempo de Ejecución	53
5.13. Comunicación interceptada.....	56
5.14. Inadecuada gestión de sesiones: Envío de peticiones sin token JWT	59
5.15. Permisos Excesivos en el Entitlements.plist	62
5.16. Copia de seguridad de la aplicación habilitada	65
5.17. Ausencia de controles de PREVENCIÓN DE USO en dispositivos con privilegios de superusuario	68
5.18. Múltiples vulnerabilidades en bibliotecas de terceros y dependencias.....	75
5.19. Debilidades en el protocolo SSL/TLS.....	78
5.20. Exposición de datos sensibles a través de propiedades de accesibilidad.....	81
5.21. Formulario susceptible ante ataques recurrentes	85
5.22. Envío de información sensible en texto claro	90
5.23. Configuración inadecuada en la comunicación.....	93
5.24. Inadecuada protección de información sensible	96
5.25. APK instalable en versiones de Android con vulnerabilidades	101
5.26. Envío de informacion sensible por el método GET	104
5.27. Inadecuada gestión de sesiones: Inicio de sesión en 2 dispositivos móviles de manera simultanea	107

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 4 de 132

5.28.	Permisos excesivos del Sistema	110
5.29.	Exposición de información innecesaria en el cuerpo del token JWT	113
5.30.	Debilidades en las cabeceras del protocolo HTTP	116
5.31.	Enumeración de directorios y archivos	124
5.32.	Posible uso de APIs inseguras en binario	127
5.33.	Posible uso de función insegura en binario	130

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 5 de 132

Introducción

Kunak Consulting ha llevado a cabo un servicio de Ethical Hacking a los sistemas de CAJA MAYNAS. Mediante este servicio se ha determinado el nivel de riesgo de ciberseguridad que poseen los elementos tecnológicos de la organización desde una perspectiva interna y externa.

Las pruebas se realizaron desde las siguientes perspectivas (escenario):

1. **BLACKBOX (caja negra):** la perspectiva de un usuario normal; es decir, sin privilegios y sin conocer nombres de usuarios o contraseñas de la organización.
2. **GRAYBOX (caja gris):** la perspectiva de un usuario con acceso al sistema, es decir, se brindaron credenciales de acceso para las pruebas al sistema.

Sobre este escenario se incluye la revisión de un marco de los principales componentes tecnológicos de la organización, entendiendo estos como servidores, equipos de comunicaciones y dispositivos de seguridad.

La identificación de vulnerabilidades incluye la revisión de configuraciones con relación a las buenas prácticas de programación, falta de actualización del software utilizado, uso de configuraciones por defecto, configuraciones débiles o erróneas, entre otras vulnerabilidades técnicas.

Es necesario indicar también que las pruebas son un medio para verificar la efectividad de las políticas y controles de seguridad de la información que existen actualmente en la organización.

Finalmente, se generan recomendaciones a partir de los resultados obtenidos para corregir los problemas encontrados.

1. ALCANCE

La prueba de Ethical hacking se realizó a los siguientes activos:

Nº	Sistema	Sistema Operativo
1	Banca Móvil	Android
2	Banca Móvil	iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 6 de 132

2. METODOLOGÍA DE EXPLOTACIÓN

La metodología utilizada por Kunak Consulting para la identificación de las vulnerabilidades identificadas desde la red interna y externa como parte del servicio de Ethical Hacking se encuentran soportadas en los estándares:

2.1. OSSTMM v3 (Open Source Security Testing Methodology Manual) y NIST SP 800 - 115

OSSTMM, (Open Source Security Testing Methodology Manual), el Manual de la Metodología Abierta de Comprobación de la Seguridad es uno de los estándares profesionales más completos y comúnmente utilizados en Auditorías de Seguridad para revisar la Seguridad de los Sistemas desde Internet. Incluye un marco de trabajo que describe las fases que habría que realizar para la ejecución de la auditoría.

La metodología sugerida por la NIST SP 800-115 incluye las siguientes fases:



2.2. ISSAFF (Information Systems Security Assessment Framework)

ISSAFF, (Information Systems Security Assessment Framework), la metodología de test de penetración ISSAF está diseñada para evaluar la red de trabajo, sistemas y control de aplicaciones.

Está enfocada en tres fases:



	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 7 de 132

2.3. OWASP v4 (Open Web Application Security Project)

La metodología utilizada por Kunak Consulting para la evaluación de seguridad en aplicaciones web y sistemas de información como parte del servicio de Ethical Hacking y Análisis de Vulnerabilidades se encuentra soportada por OWASP e incluye los siguientes controles de seguridad:

Nro. Control	CODIGO OWASP	PRUEBA A REALIZAR
Obtención de Información		
1	OTG-INFO-001	Realizar el descubrimiento y reconocimiento de divulgación de información basados en motores de búsqueda
2	OTG-INFO-002	Identificar el software de Web
3	OTG-INFO-003	Revisar archivos con Metadata en búsqueda de divulgación de información
4	OTG-INFO-004	Enumerar las aplicaciones en el servidor web
5	OTG-INFO-005	Revisar los comentarios y Metadata de las páginas web buscando divulgación de información
6	OTG-INFO-006	Identificar los puntos de entrada de las aplicaciones
7	OTG-INFO-007	Mapear las rutas de ejecución a través de las aplicaciones
8	OTG-INFO-008	Identificar el Framework usado por las aplicaciones
9	OTG-INFO-009	Identificar la aplicación
10	OTG-INFO-010	Mapear la arquitectura de las aplicaciones
Evaluación de la Gestión de Configuración y Despliegue		
11	OTG-CONFIG-001	Evaluar la configuración de la red/infraestructura
12	OTG-CONFIG-002	Evaluar la configuración de la plataforma de las aplicaciones
13	OTG-CONFIG-003	Evaluar el manejo de las extensiones de nombres de archivos en búsqueda de información sensible
14	OTG-CONFIG-004	Buscar información sensible en archivos de copia de seguridad y no referenciados
15	OTG-CONFIG-005	Enumerar las interfaces de administración de infraestructura y de las aplicaciones
16	OTG-CONFIG-006	Evaluar los métodos HTTP
17	OTG-CONFIG-007	Evaluar la seguridad estricta en el transporte vía HTTP
18	OTG-CONFIG-008	Evaluar el cumplimiento de las políticas de "dominio s cruzados" para las aplicaciones tipo RIA (aplicaciones de Internet enriquecidas)
Evaluar la Gestión de Identidades		
19	OTG-IDENT-001	Evaluar las definiciones de roles
20	OTG-IDENT-002	Evaluar los procesos de registro de usuarios
21	OTG-IDENT-003	Evaluar el proceso de provisionamiento de las cuentas de usuario
22	OTG-IDENT-004	Evaluar la enumeración de cuentas de usuario y las "cuentas adivinables"
23	OTG-IDENT-005	Evaluar las políticas débiles o no forzadas para nombres de usuarios
24	OTG-IDENT-006	Evaluar los permisos de cuentas tipo Invitado/Practicante
25	OTG-IDENT-007	Evaluar el proceso de suspensión/reactivación de cuentas
26	OTG-AUTHN-001	Evaluación de credenciales transportadas sobre un canal no encriptado
27	OTG-AUTHN-002	Evaluar las credenciales default
28	OTG-AUTHN-003	Evaluar los mecanismos débiles de bloqueo de cuentas
29	OTG-AUTHN-004	Evaluar la evasión del esquema de autenticación
30	OTG-AUTHN-005	Evaluar la funcionalidad de recordar contraseña
31	OTG-AUTHN-006	Evaluar las debilidades del caché del browser
32	OTG-AUTHN-007	Evaluar las políticas de contraseña débiles
33	OTG-AUTHN-008	Evaluar los mecanismos débiles de recuperación de acceso mediante pregunta/respuesta
34	OTG-AUTHN-009	Evaluar funcionalidades débiles de cambio de contraseña o reinicialización
35	OTG-AUTHN-010	Evaluar autenticaciones débiles mediante canales alternos
Evaluación de Autorización		
36	OTG-AUTHZ-001	Evaluar el recorrido de directorios/inclusión de archivos
37	OTG-AUTHZ-002	Evaluar la evasión del esquema de autorización
38	OTG-AUTHZ-003	Evaluar el escalamiento de privilegios
39	OTG-AUTHZ-004	Evaluar las referencias inseguras a objetos de forma directa

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 8 de 132

Evaluar el Manejo de Sesiones		
40	OTG-SESS-001	Evaluar la evasión del esquema de manejo de sesiones
41	OTG-SESS-002	Evaluar los atributos de las cookies
42	OTG-SESS-003	Evaluar la "fijación" de sesiones
43	OTG-SESS-004	Evaluar variables de sesión expuestas
44	OTG-SESS-005	Evaluar la ocurrencia de falsificación de requerimientos cruzados (Cross Site Request Forgery)
45	OTG-SESS-006	Evaluar la funcionalidad de termino de sesión (logout)
46	OTG-SESS-007	Evaluar el tiempo máximo de inactividad por sesión
47	OTG-SESS-008	Evaluar el uso inapropiado de variables de sesión (Session puzzling).
Evaluar la Validación de Datos		
48	OTG-INPVAL-001	Evaluar Cross Site Scripting Reflejado
49	OTG-INPVAL-002	Evaluar Cross Site Scripting Almacenado
50	OTG-INPVAL-003	Evaluar la manipulación de verbos HTTP
51	OTG-INPVAL-004	Evaluar la "contaminación" de parámetros HTTP
52	OTG-INPVAL-005	Evaluar inyecciones de SQL
53	OTG-INPVAL-006	Evaluar inyecciones de LDAP
54	OTG-INPVAL-007	Evaluar inyecciones en datos generados por una herramienta ORM (Object Relational Mapping)
55	OTG-INPVAL-008	Evaluar inyecciones de XML
56	OTG-INPVAL-009	Evaluar inyecciones de SSI
57	OTG-INPVAL-010	Evaluar inyecciones de XPath
58	OTG-INPVAL-011	Evaluar inyecciones IMAP/SMTP
59	OTG-INPVAL-012	Evaluar inyecciones de código
60	OTG-INPVAL-013	Evaluar inyecciones de comandos
61	OTG-INPVAL-014	Evaluar desbordamiento de buffer
62	OTG-INPVAL-015	Evaluar vulnerabilidades incubadas
63	OTG-INPVAL-016	Evaluar la división y/o encubrimiento de tráfico HTTP
64	OTG-ERR-001	Análisis de códigos de error
65	OTG-ERR-002	Análisis de trazados de pila
Criptografía		
66	OTG-CRYPST-001	Evaluar cifrados débiles de SSL/TSL, protección protecciones insuficientes en el transporte
67	OTG-CRYPST-002	Evaluar ataques del tipo "Padding Oracle"
68	OTG-CRYPST-003	Evaluar información sensible enviada por canales no encriptados.
Evaluación de la Lógica de Negocio		
69	OTG-BUSLOGIC-001	Evaluar la validación de datos de la lógica negocio
70	OTG-BUSLOGIC-002	Evaluar la posibilidad de falsificar peticiones
71	OTG-BUSLOGIC-003	Evaluar los controles de integridad
72	OTG-BUSLOGIC-004	Evaluar el tiempo de procesamiento
73	OTG-BUSLOGIC-005	Evaluar la cantidad de veces que una función puede ser usada sin límites
74	OTG-BUSLOGIC-006	Evaluar las desviaciones en flujos de trabajo
75	OTG-BUSLOGIC-007	Evaluar las defensas ante malos usos de las aplicaciones
76	OTG-BUSLOGIC-008	Evaluar la carga de archivos de tipos no esperados
77	OTG-BUSLOGIC-009	Evaluar la carga de archivos con contenido malicioso
Evaluación del Lado Cliente		
78	OTG-CLIENT-001	Evaluar Cross Site Scripting basados en DOM (Document Object Model)
79	OTG-CLIENT-002	Evaluar la ejecución de JavaScript
80	OTG-CLIENT-003	Evaluar inyecciones de HTML
81	OTG-CLIENT-004	Evaluar redirecciones de URL en el Lado Cliente
82	OTG-CLIENT-005	Evaluar inyecciones de CSS
83	OTG-CLIENT-006	Evaluar la manipulación de recursos del Lado Cliente
84	OTG-CLIENT-007	Evaluar "Cross Origin Resource Sharing"
85	OTG-CLIENT-008	Evaluar "Cross Site Flashing"
86	OTG-CLIENT-009	Evaluar "Clickjacking"
87	OTG-CLIENT-010	Evaluar WebSockets
88	OTG-CLIENT-011	Evaluar "Web Messaging" (Cross Document Messaging)
89	OTG-CLIENT-012	Evaluar almacenamiento local

3. METODOLOGÍA DE CUANTIFICACIÓN DE LAS VULNERABILIDADES (CVSS)

La metodología utilizada por Kunak Consulting para la valoración del riesgo de seguridad de información de las vulnerabilidades identificadas como parte del servicio de Ethical Hacking se encuentra soportada en el estándar CVSS (Common Vulnerability Scoring System) y la experiencia de nuestros consultores.

El CVSS es una iniciativa pública concebida por la National Infrastructure Assurance Council (NIAC) de EE. UU, un grupo que provee de recomendaciones al Department of Homeland Security de los EE.UU. Entre las organizaciones que lo adoptaron tempranamente destacan Cisco, US National Institute of Standards and Technology (NIST), Qualys y Oracle. En la actualidad, el CVSS está bajo la custodia del Forum for International Response Teams (FIRST) y es aceptada por diversas organizaciones relacionadas a seguridad de información: IBM, HP, CISCO, MICROSOFT, McAfee, Symantec, etc.

Entre los beneficios que ofrece el CVSS están:

1. **Puntuación estándar de vulnerabilidades**: El CVSS es neutro desde el punto de vista de las aplicaciones, permitiendo que distintas organizaciones asignen una puntuación a sus vulnerabilidades de TI a través de un único esquema.
2. **Puntuación contextualizada**: La puntuación asignada por una organización corresponde al riesgo que la vulnerabilidad representa para dicha organización.
3. **Sistema abierto**: El CVSS provee todos los detalles sobre los parámetros usados en la generación de cada puntuación permitiendo comprender tanto el razonamiento que sustenta una puntuación como el significado de diferencias entre puntuaciones.

Las puntuaciones asignadas por el CVSS se derivan de los tres grupos de métricas siguientes:

- **Base**: Este grupo representa las propiedades de una vulnerabilidad que son inmutables en el tiempo, específicamente: complejidad de acceso, vector de acceso, y grado en que compromete la confidencialidad, integridad y disponibilidad del sistema.
- **Temporal**: Este grupo mide las propiedades de una vulnerabilidad que sí cambian en el tiempo, como por ejemplo la existencia de parches o código para su explotación.
- **Entorno**: Este grupo mide las propiedades de una vulnerabilidad que son representativas de los ambientes de uso de las TI como por ejemplo la prevalencia de sistemas afectados y pérdidas potenciales.

Para mayor detalle del mecanismo utilizado para la valoración del riesgo asociado a CVSS versión 3, recomendamos visitar la siguiente página web: <http://www.first.org/cvss>

Cuantificación y Calificación de las vulnerabilidades identificadas

Categoría del riesgo	Ninguno	Bajo	Medio	Alto	Crítico
Cuantificación CVSS	0 – 0	0.1 – 3.9	4.0 – 6.9	7.0 – 8.9	9.0 – 10

4. RESUMEN DE LA PRUEBA REALIZADA

Nº	Descripción de la vulnerabilidad identificada y el riesgo asociado	Categoría	CVSS
APLICACIÓN MOVIL - HOME BANKING Y iOS			
1	Inadecuada gestión de acceso: Acceso a saldos y movimientos de otras cuentas	CRITICO	9.4
2	Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta	CRITICO	9.4
3	Ausencia de la verificación de Integridad de Binario	ALTO	8.6
4	Bypass del Código de verificación SMS	ALTO	8.2
5	Inadecuado cifrado a nivel de la capa de aplicación	ALTO	8.2
6	Configuración errónea en el archivo Info.plist	ALTO	8.2
7	Almacenamiento de información de sesión en texto claro	ALTO	8.1
8	Falta de Ofuscación de claves de API y datos sensibles en binario	ALTO	7.7
9	Falta de Protección contra Depuración	ALTO	7.7
10	Exposición de archivos de configuración sensibles	ALTO	7.5
11	Inadecuado proceso de time out	ALTO	7.3
12	inyección de código en Tiempo de Ejecución	ALTO	7.2
13	Comunicación interceptada	MEDIO	6.5
14	Inadecuada gestión de sesiones: Envío de peticiones sin token JWT	MEDIO	6.5
15	Permisos Excesivos en el Entitlements.plist	MEDIO	6.5
16	Copia de seguridad de la aplicación habilitada	MEDIO	6.4
17	Ausencia de controles de prevención de uso en dispositivos con privilegios de superusuario	MEDIO	5.9
18	Múltiples vulnerabilidades en bibliotecas de Terceros y Dependencias	MEDIO	5.6
19	Debilidades en el protocolo SSL/TLS	MEDIO	5.4
20	Exposición de datos sensibles a través de propiedades de accesibilidad	MEDIO	5.4
21	Formulario susceptible ante ataques recurrentes	MEDIO	5.3
22	Envío de información sensible en texto claro	MEDIO	5.3
23	Configuración inadecuada en la comunicación	MEDIO	5.3
24	Inadecuada protección de información sensible	MEDIO	5.3
25	APK instalable en versiones de Android con vulnerabilidades	MEDIO	4.8
27	Envío de información sensible por el método GET	MEDIO	4.8
27	Inadecuada gestión de sesiones: Inicio de sesión en 2 dispositivos móviles de manera simultanea	MEDIO	4.8
28	Permisos excesivos del Sistema	MEDIO	4.8
29	Exposición de información innecesaria en el cuerpo del token JWT	BAJO	3.7
30	Debilidades en las cabeceras del protocolo HTTP	BAJO	3.7
31	Enumeración de directorios y archivos	BAJO	3.7
32	Posible uso de APIs inseguras en binario	BAJO	3.1
33	Posible uso de función insegura en binario	BAJO	3.1

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales CAJA MAYNAS	Código: EH-CMACMYS- IT
		Versión: 2.0
	INFORME TÉCNICO BANCA MÓVIL	Fecha: 02/04/2025
		Página: 12 de 132

```
GET
/api/v1/WebBanca/Product/ConsultSaldoDispCuentas?cPersCod=1094800027111&cCtacd=10
9482321002492598&nTipoCanal=1 HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json
Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJVc2VyRGF0YSI6IkdNNYXluYXNBUEkiLCJuYmYiOiJl
E3NDI5MzQyMTQsImV4cCI6MTc0MzAyMDYxNCwiaWF0IjoxNzQyOTM0MjE0LjCjpc3MiOiJodH
RwOi8vbG9jYXRob3N0OjIwMjUyYXVkljoiaHR0cDovL2xvY2FsaG9zdDoyMDIxLyJ9.LuMY3w
pVp2gBODO1GYQTqNr6SUoQCK7tmvdDAGBbaS4
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0
```

- Se cambia los parámetros “cPersCod” y “cCtacd” por los de otro usuario y nos muestra sus últimos movimientos

CONSECUENCIAS

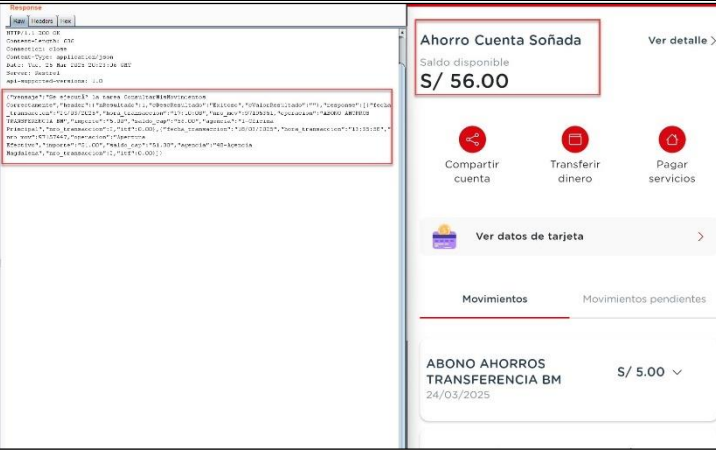
- Pérdida de confidencialidad
- Se expone información privada de los clientes

REMEDIACIÓN

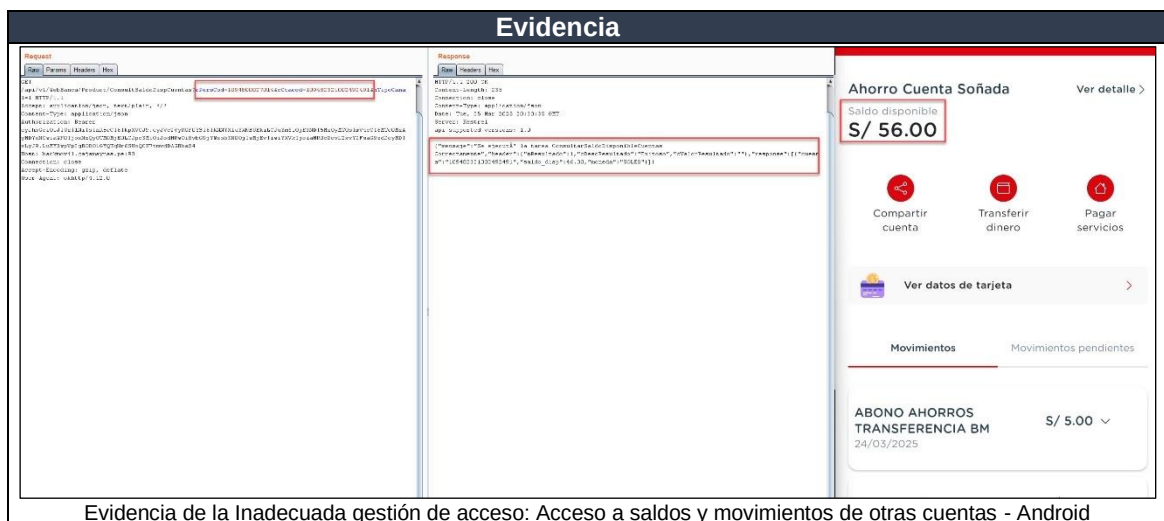
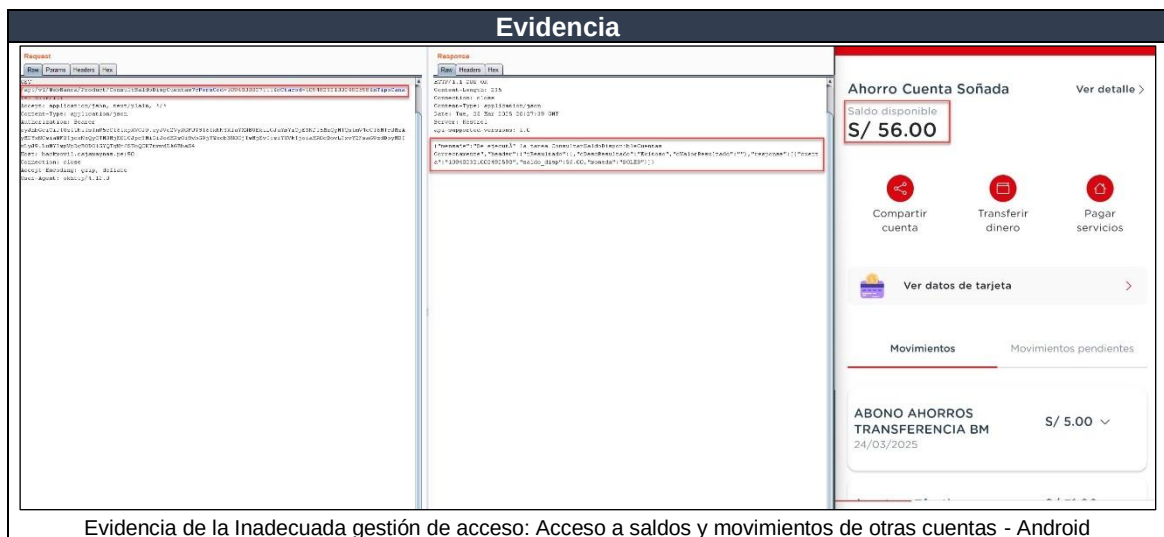
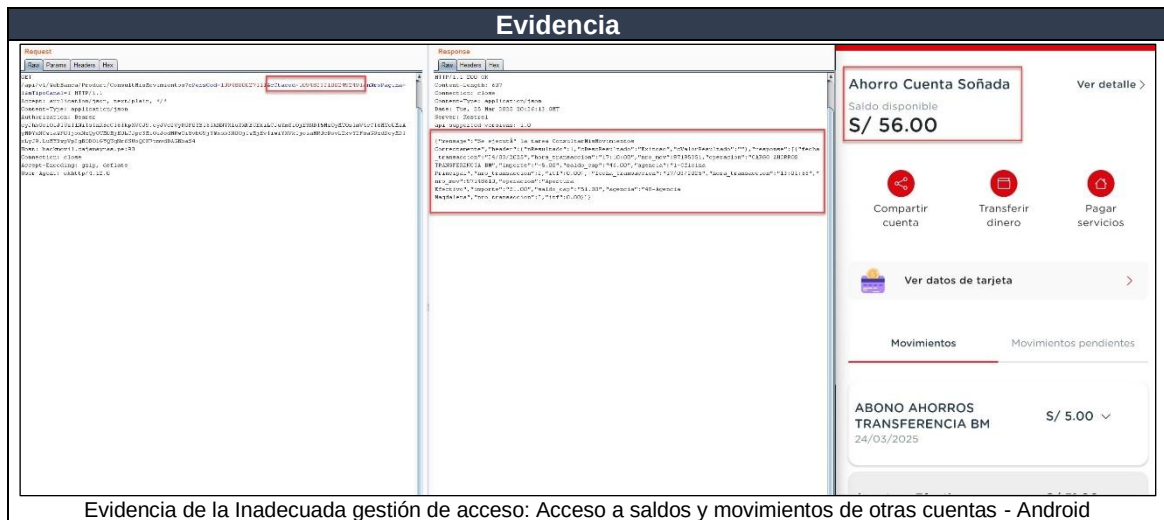
- Se recomienda que la aplicación verifique solo con el token de sesión al momento de realizar las consultas de movimientos y saldos.

Evidencia





Evidencia de la Inadecuada gestión de acceso: Acceso a saldos y movimientos de otras cuentas - Android



	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 14 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Alto
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	9.4
Subpuntuación de Impacto	5.5
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	9.4

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 15 de 132

5.2. Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta

Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta		RIESGO CRITICO							
		CVSS	9.4						
Descripción	La aplicación del banco tiene un error al realizar transferencias. Un atacante puede cambiar los números de cuenta durante la transferencia, haciendo que el dinero se envíe a su propia cuenta en lugar de a la cuenta del destinatario real. Esto ocurre porque la aplicación no verifica correctamente quién tiene permiso para cambiar las cuentas								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante podría realizar transferencias no autorizadas con otros usuarios.									
RIESGO DE LA VULNERABILIDAD									
- Robo directo de fondos de los usuarios afectados - Posibilidad de realizar transferencias fraudulentas a gran escala									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Ingresamos a la aplicación móvil, luego vamos a la opción de realizar transferencia 2. Interceptamos las peticiones para capturar la solicitud de transferencia de un usuario legítimo 3. Modificamos los parámetros de la solicitud, intercambiando el número de cuenta "cCtacod " y el código de persona "cPersCod" del remitente con los del destinatario 4. Se envía la solicitud modificada al servidor. 5. El servidor, al no realizar una validación adecuada de los parámetros, procesa la transferencia y envía los fondos a la cuenta del atacante									
CONSECUENCIAS									
- Pérdidas financieras directas para los usuarios									
REMEDIACIÓN									
- Implementar una validación exhaustiva de todos los parámetros de la transferencia en el lado del servidor, verificando que los números de cuenta y códigos de persona coincidan con los usuarios autorizados. - Utilizar identificadores únicos y aleatorios para las cuentas y los usuarios, en lugar de información fácilmente manipulable. - Asegurar que la aplicación verifique que el usuario que realiza la transferencia tenga permisos para mover fondos desde la cuenta de origen - Usar tokens de seguridad para autenticar y autorizar las transacciones. - Limitar los intentos de transacciones fallidas, y bloquear cuentas después de determinado número de intentos									

< Operaciones

Cuenta origen

AHORRO CUENTA SOÑADA
109482321002492491

S/ 46.00 

109482321002492598

S/ 5.00

Continuar

Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

Original request		Edited request		Response	
Date	Params	Headers	Max	Date	Max
		<pre>GET /api/v1/webSocket/Transf/ConfirmationsTransf/0?PaaSCode=U948060077114eCcacodXcIgrms=U9480232J0K240256RACcacodBeasino=U9480232J0K240256RACMonos=5.0UnAtToTransf=14nTioCanal=1 HTTP/1.1 Accept: application/json, text/plain, */* Content-Type: application/json Authorization: Basic: Host: backmooft.com User-Agent: okhttp/4.12.0</pre>			

Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

Evidencia

Confirmación de la operación

Puedes transferir hasta 5 veces por día

Tipo de operación

Transferencia a otras cuentas Caja Maynas

Cuenta origen

109482321002492598
AHORRO CUENTA
SOÑADA-SOLES

Cuenta destino

109482321002492491
AHORRO CUENTA
SOÑADA-SOLES

Nombre

joel josh bustamante
peredo

Monto a transferir

S/ 5.00

Comisión

S/ 0.00

I.T.F.

S/ 0.00

Monto total

S/ 5.00

Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

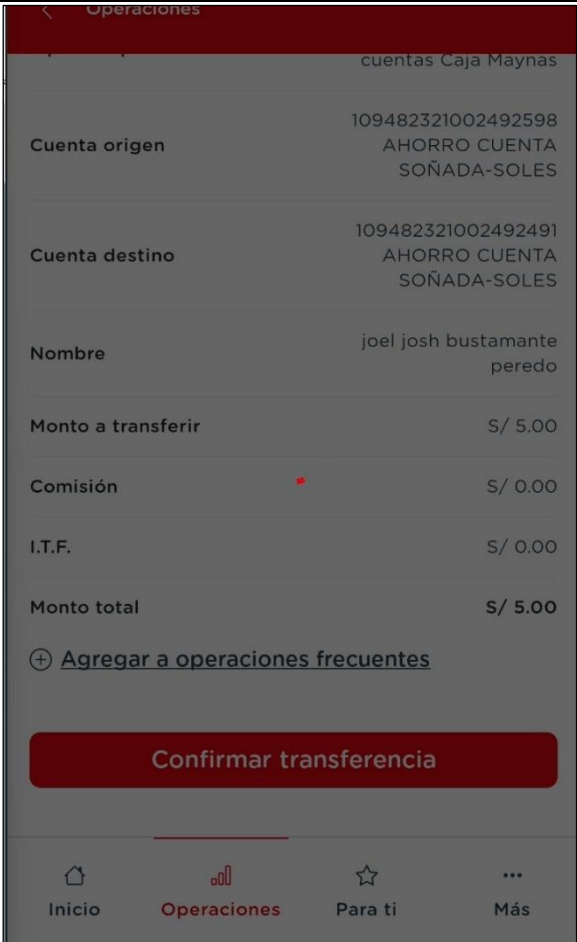
	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 18 de 132

Evidencia



Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

Evidencia



Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

Evidencia

Tipo de cambio: Compra: 3.555 | Venta: 3.715

Hola, Joel

¿Qué deseas hacer hoy?

Ocultar saldo 



Transferir dinero



Pagar servicios



Pagar crédito

Mis productos

Ver todo >

AHORRO CUENTA SOÑADA

109482321002492491

S/ 51.00

Evidencia de la Inadecuada implementación de transacción: Transferencia NO autorizada de cliente a mi cuenta - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 20 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Alto
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	9.4
Subpuntuación de Impacto	5.5
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	9.4

5.3. Ausencia de la verificación de Integridad del Binario

Ausencia de la verificación de Integridad del Binario		RIESGO ALTO							
		CVSS	8.6						
Descripción	Si la aplicación no valida cambios en el binario, un atacante podría modificar el binario sin que la aplicación lo detecte, permitiendo la ejecución de código malicioso o alteraciones no autorizadas.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante descarga la aplicación legítima, la modifica inyectando código malicioso (como un troyano, spyware o ransomware), y luego la vuelve a empaquetar y distribuir a través de tiendas de aplicaciones de terceros no oficiales o mediante ingeniería social. Los usuarios que instalen esta versión modificada ejecutarán el código malicioso junto con la funcionalidad original de la aplicación. - Si el proceso de actualización de la aplicación no verifica la integridad de la nueva versión antes de instalarla, un atacante podría interceptar o manipular el paquete de actualización para distribuir una versión comprometida.									
RIESGO DE LA VULNERABILIDAD									
- Un atacante podría inyectar código arbitrario en la aplicación, permitiendo la realización de acciones no deseadas en el dispositivo del usuario. - El código inyectado podría recopilar y enviar información personal, credenciales de inicio de sesión, datos bancarios u otra información confidencial a servidores controlados por el atacante									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Primero, ejecutamos el comando shasum para obtener el hash del binario original luego modificamos el binario. Agregamos el texto "test" al final del binario. Este es un cambio simple para ver si la aplicación detecta la modificación. Hash original: 6a901e8782bb765d2facfbb1de80a16243d86dc2 Hash modificado: 4c22d37608244c8a48c3d5e95adeae130efae8a1 2. Esto indica que la aplicación no detecta la modificación del binario. No valida la integridad del binario, lo que constituye una vulnerabilidad de seguridad.									
CONSECUENCIAS									
- Compromiso de la seguridad del dispositivo del usuario - Pérdida de datos personales y financieros									
REMEDIACIÓN									
- La aplicación debe verificar su propio código en tiempo de ejecución para detectar cualquier modificación no autorizada. Esto puede incluir la verificación de sumas de comprobación (checksums) o firmas digitales del código.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 22 de 132

- Asegurarse de que la aplicación esté firmada digitalmente con un certificado válido y verificar la firma al inicio de la aplicación.
- Utilizar técnicas de ofuscación de código para dificultar la ingeniería inversa y la modificación del binario. Empaquetar el código de forma segura puede también dificultar la manipulación.

Evidencia
<pre> omargavidia@Omars-MacBook-Air Payload % shasum /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas 6a901e8782bb765d2facfbb1de80a16243d86dc2 /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas omargavidia@Omars-MacBook-Air Payload % echo "test" >> /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas omargavidia@Omars-MacBook-Air Payload % shasum /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas 4c22d37608244c8a48c3d5e95adeae130efae8a1 /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas omargavidia@Omars-MacBook-Air Payload % █ </pre>
Evidencia de la ausencia de la verificación de integridad del binario - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 23 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	8.6
Subpuntuación de Impacto	4.7
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	8.6

5.4. Bypass del código de verificación SMS

Bypass del código de verificación SMS		RIESGO ALTO							
		CVSS	8.2						
Descripción	Cuando alguien hace una transferencia de dinero, el banco envía un código de seguridad por mensaje de texto (SMS) para confirmar que es esa persona quien realiza la operación. Sin embargo, hay un error en la aplicación que permite que un atacante cambie a quién se envía ese código. En lugar de llegar al teléfono de quien hace la transferencia, el código se envía al teléfono de otra persona, permitiendo que esta otra persona autorice la transferencia								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante puede cambiar el número de destino del código de seguridad									
RIESGO DE LA VULNERABILIDAD									
- El código de SMS de verificación podría llegar al número de un atacante por lo que podría realizar operaciones NO autorizadas.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de Identificación: 1. Se ingreso a la aplicación 2. Se procedió a realizar una transferencia 3. Como último paso quedaba validar el código SMS que se envía en la siguiente petición <pre>POST /api/v1/WebBanca/Token/GuardarSMS HTTP/1.1 Accept: application/json, text/plain, */* Content-Type: application/json; charset=UTF-8 Content-Length: 114 Host: backmovil.cajamaynas.pe:90 Connection: close Accept-Encoding: gzip, deflate User-Agent: okhttp/4.12.0 {"cDescripcion":"2","cID":"1094800027014","cID_Dispositivo":"duqwOz1zREamPFLus4IkX","cOperacion":"2","nEstado":1}</pre> 4. Se intercepta la petición y se cambia el parámetro “cID” de manera que el SMS se envía a un número diferente del registrado en dicha cuenta.									
CONSECUENCIAS									
- Un eventual atacante podría realizar transacciones fraudulentas. - Posibles pérdidas monetarias por parte de los clientes.									
REMEDIACIÓN									
Se recomienda que la petición donde se envía el código SMS cuente con un token de sesión, de manera que el sistema lo valide con este y no con parámetro que puede ser alterado.									

Evidencia

Transferencia a otra cuenta Caja Maynas

Cuenta origen

AHORRO CUENTA SOÑADA
109482321002492598

S/ 51.00

Cuenta destino

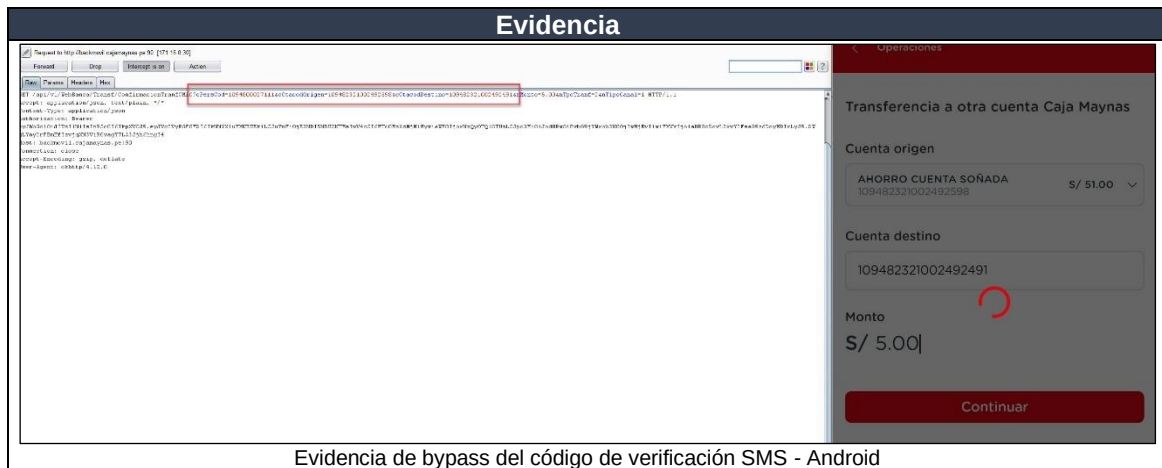
109482321002492491

Monto

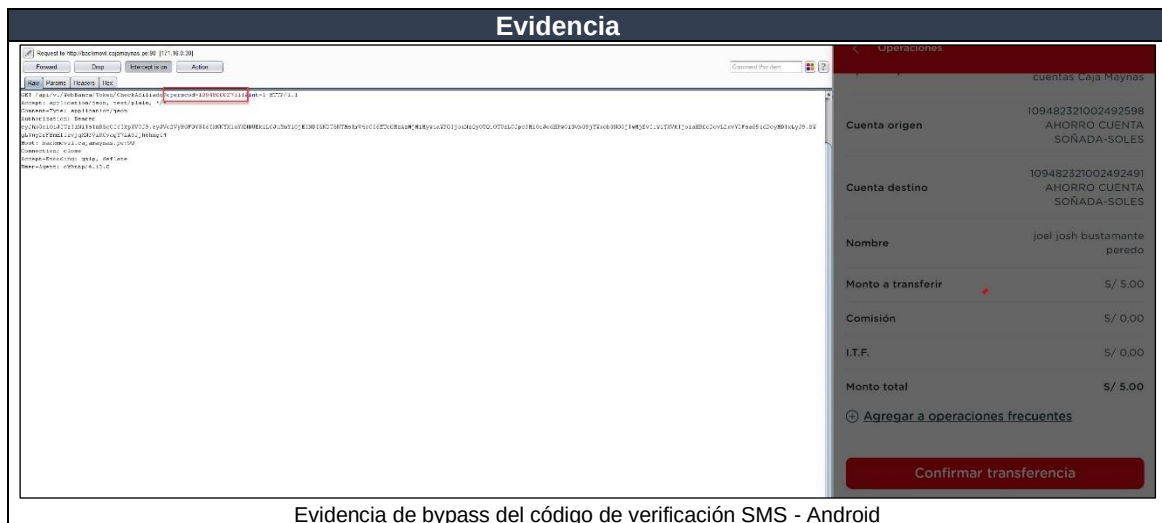
S/ 5.00|

Continuar

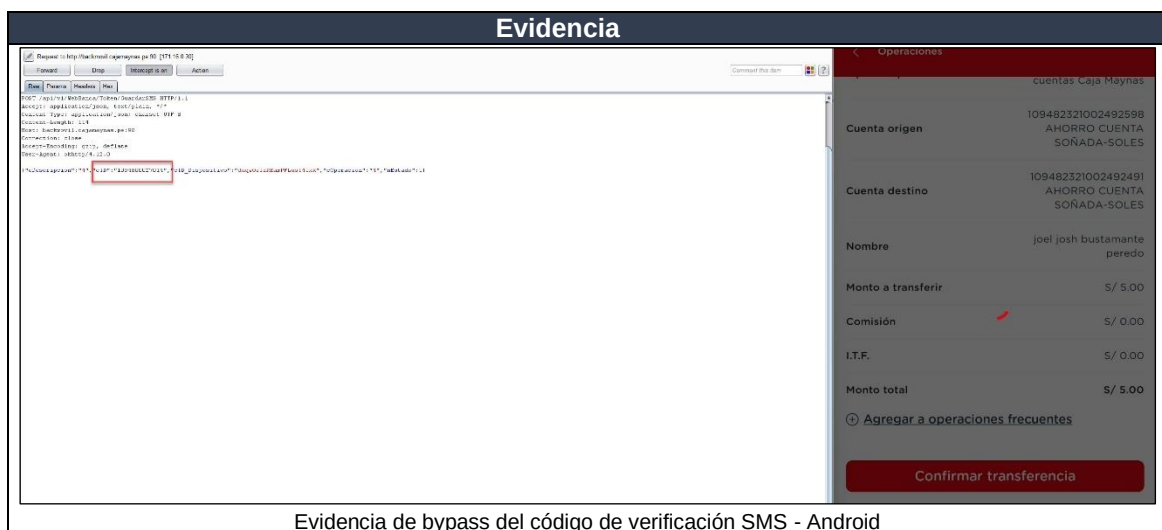
Evidencia de bypass del código de verificación SMS - Android



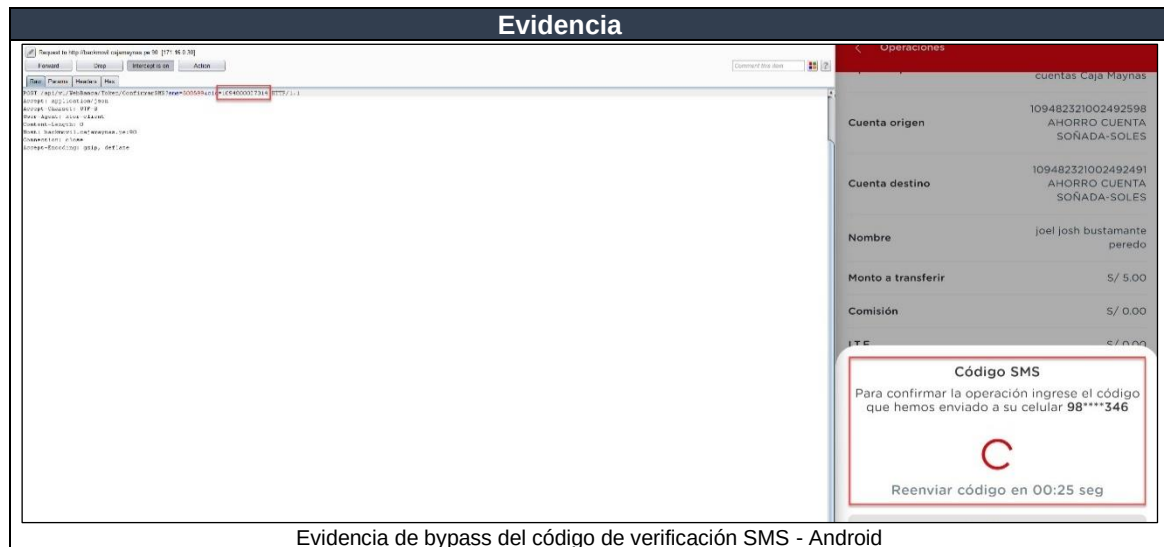
Evidencia de bypass del código de verificación SMS - Android



Evidencia de bypass del código de verificación SMS - Android



Evidencia de bypass del código de verificación SMS - Android



Evidencia de bypass del código de verificación SMS - Android



Evidencia de bypass del código de verificación SMS - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 28 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Alto
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	8.2
Subpuntuación de Impacto	4.2
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	8.2

5.5. Inadecuado cifrado a nivel de la capa de aplicación

Inadecuado cifrado a nivel de capa de aplicación		RIESGO ALTO							
		CVSS	8.2						
Descripción	Durante las presentes pruebas se pudo identificar que, al momento de iniciar sesión en el aplicativo móvil, el número de tarjeta se envía en texto claro sin ningún mecanismo de cifrado.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante podría interceptar el tráfico y visualizar en texto claro el número de tarjeta y contraseña.									
RIESGO DE LA VULNERABILIDAD									
- Un eventual atacante podría obtener credenciales de acceso a cuenta de clientes.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de Identificación: 1. Se inicio sesión en el sistema 2. Se pudo visualizar la siguiente petición: <pre>POST /api/v1/WebBanca/Auth/ValidaIngreso HTTP/1.1 Accept: application/json, text/plain, */* Content-Type: application/json; charset=UTF-8 Content-Length: 246 Host: backmovil.cajamaynas.pe:90 Connection: close Accept-Encoding: gzip, deflate User-Agent: okhttp/4.12.0 {"cContrasena":"6ce3e7fc6dcb81dc9f3dcf06168916f217dec18daeb489b49c943e4d13496c8f1fbb198d89b74a852060d3140e96402be834adfeba39b6f7f3ed939ceb7349e0","cIdDisp":"duqwOz1zREamPFLusl4lkX","cNumtarjeta":"4697100201159447","nTipoCanal":1,"nTipoTarjeta":1}</pre> 3. Se pudo visualizar que el envío de la tarjeta de crédito se realiza en texto claro. 4. De la misma manera al ingresar a la opción "Olvide mi Contraseña" el número de tarjeta y contraseña se envían sin cifrar <pre>GET /api/v1/WebBanca/Auth/VerificarPin?cNumTarjeta=4697100201159447&cClave=0102 HTTP/1.1 Accept: application/json, text/plain, */* Content-Type: application/json Host: backmovil.cajamaynas.pe:90 Connection: close Accept-Encoding: gzip, deflate User-Agent: okhttp/4.12.0</pre>									
Importante: - Es importante mencionar que solo se detectó un cifrado de la contraseña.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 30 de 132

CONSECUENCIAS

- Posible pérdida de dinero de clientes de la organización.

REMEDIACIÓN

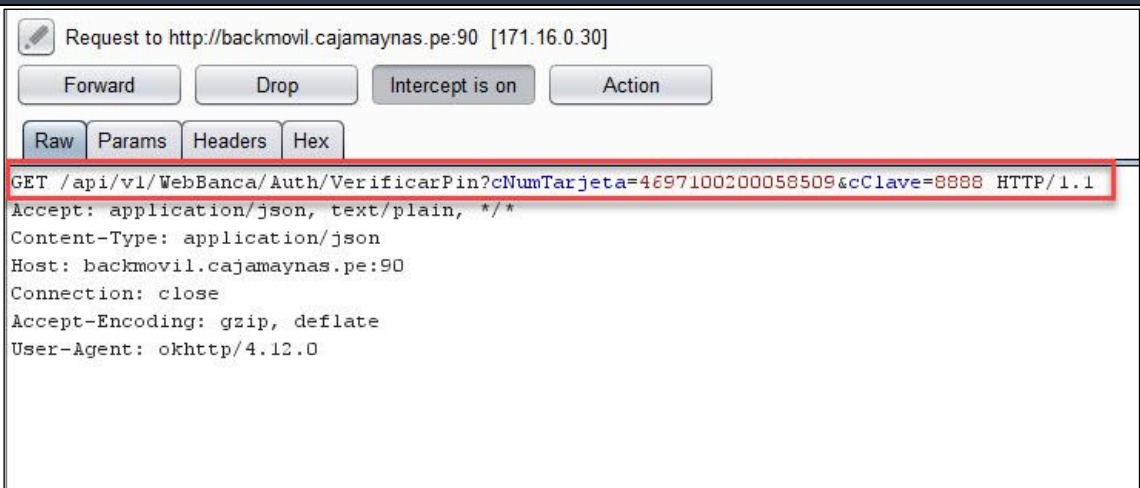
- Se recomienda realizar un cifrado del número de tarjeta y contraseña en todas peticiones donde estos sean requeridos.

Evidencia



Evidencia del inadecuado cifrado a nivel de la capa de aplicación - Android

Evidencia



Evidencia del inadecuado cifrado a nivel de la capa de aplicación - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 31 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	8.2
Subpuntuación de Impacto	4.2
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	8.2

5.6. Configuración errónea en el archivo Info.plist

Configuración errónea en el archivo Info.plist		RIESGO ALTO							
		CVSS	8.2						
Descripción	La inclusión de la GoogleMapsAPIKey directamente en el archivo Info.plist representa una vulnerabilidad crítica bajo la categoría de M8: Security Misconfiguration porque al estar hardcodeda, cualquier atacante que tenga acceso al archivo IPA puede extraer la clave y utilizarla para hacer llamadas a la API de Google Maps sin autorización								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante descarga el archivo IPA de la aplicación (obtenible de tiendas de aplicaciones o mediante otros medios) y lo analiza utilizando herramientas de inspección de archivos IPA o desempaquetadores. El archivo Info.plist es un archivo de texto plano (generalmente en formato XML) dentro del paquete IPA, y la GoogleMapsAPIKey hardcodeda puede ser fácilmente encontrada buscando la clave específica o patrones relacionados con Google Maps. - Existen scripts y herramientas automatizadas diseñadas para analizar archivos IPA y extraer información sensible como claves de API, URLs y otros datos de configuración. Un atacante podría utilizar estas herramientas para escanear múltiples aplicaciones en busca de claves expuestas.									
RIESGO DE LA VULNERABILIDAD									
- Un atacante podría utilizar la GoogleMapsAPIKey para realizar solicitudes a la API de Google Maps desde sus propios servidores o aplicaciones. Esto podría incluir la obtención de mapas, la realización de búsquedas de lugares, el cálculo de rutas, etc. - Cada solicitud a la Google Maps API tiene un costo asociado y está sujeta a cuotas. Un atacante que utilice la clave expuesta podría consumir las cuotas asignadas a la organización, generando costos inesperados y potencialmente interrumpiendo el servicio de mapas para los usuarios legítimos de la aplicación. -									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Se identifico mediante el análisis estático del IPA. 2. Se realizó el análisis. 3. Se identificó que el apikey de GoogleMaps se encuentra expuesto. <pre>"DTXcodeBuild" => "16C5032a" "GoogleMapsAPIKey" => "AIzaSyCh2Ww8p-0ipVKAh_D-fFebQ0XRafhV3zQ" "LSApplicationCategoryType" => "public.app-category.finance" "LSRequiresiPhoneOS" => 1</pre>									
CONSECUENCIAS									
- La organización podría incurrir en cargos significativos por el uso no autorizado de la Google Maps API. - Google podría tomar medidas contra la cuenta de la organización si detecta un uso anómalo o malicioso de la clave.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 33 de 132

REMEDIACIÓN

- La clave nunca debe estar hardcodeada directamente en el código de la aplicación o en archivos de configuración estáticos como Info.plist.
- La aplicación móvil debe comunicarse con un servidor backend controlado por la organización para obtener la GoogleMapsAPIKey. Este servidor puede implementar mecanismos de seguridad para controlar el acceso y el uso de la clave.

Evidencia

```

"CFBundleVersion" => "36"
"DTCompiler" => "com.apple.compilers.llvm.clang.1_0"
"DTPlatformBuild" => "22C146"
"DTPlatformName" => "iphoneos"
"DTPlatformVersion" => "18.2"
"DTSDKBuild" => "22C146"
"DTSDKName" => "iphoneos18.2"
"DTXcode" => "1620"
"DTXcodeBuild" => "16C5032a"
"GoogleMapsAPIKey" => "AIzaSyCh2Ww8p-0ipVKAh_D-fFebQ0XRafhV3zQ"
"LSApplicationCategoryType" => "public.app-category.finance"
"LSRequiresiPhoneOS" => 1
"MinimumOSVersion" => "15.6"
"NSFaceIDUsageDescription" => "Autenticación con TouchID o FaceID"
"NSFileProviderDomainUsageDescription" => "Para ubicar la agencia más cercana"
"NSLocationAlwaysAndWhenInUseUsageDescription" => "Para ubicar la agencia más cercana"
"NSLocationWhenInUseUsageDescription" => "Para ubicar la agencia más cercana"
"NSPhotoLibraryAddUsageDescription" => "This app requires access to the photo library."
"UIAppFonts" => [
  0 => "GothamRoundedMedium_21022.ttf"
  1 => "GothamRoundedLight_21020.ttf"
  2 => "GothamRoundedBook_21018.ttf"
  3 => "GothamRoundedBold_21016.ttf"
]
"UIApplicationSceneManifest" => {
  "UIApplicationSupportsMultipleScenes" => 1
  "UISceneConfigurations" => {

```

Evidencia de la configuración errónea en el archivo Info.plist - iOS

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	8.2
Subpuntuación de Impacto	4.2
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	8.2

5.7. Almacenamiento de información de sesión en texto claro

Almacenamiento de información de sesión en texto claro		RIESGO ALTO							
		CVSS	8.1						
Descripción	Cuando una aplicación se comunica con un servicio web, existe un intercambio de información, así como elementos claves para acceder a información restringida solo para usuarios autorizados. Uno de los elementos claves es el token de sesión que es intercambiado cuando el usuario se autentica en el sistema a través del envío de usuario y contraseña. Ese token de sesión es el único mecanismo para acceder o prohibir el acceso a la información correspondiente. También hay información importante del usuario que puede ser usada en futuras peticiones al servidor u otros recursos en internet. En ambos casos, esta información solo debe poder ser accedida por la aplicación. Durante el análisis de vulnerabilidades, se revisó cualquier archivo dentro del dispositivo que contenga información de sesión incluyendo este token de sesión que puede ser usado para obtener información sin necesidad de hacerlo a través de la aplicación, o cualquier otra información que pueda ser aprovechada por un atacante para futuras amenazas. Se analiza las preferencias o archivos de base de datos internas que, al iniciar sesión, se pueda lograr identificar información de sesión.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un malware instalado en el dispositivo del usuario puede acceder a los archivos de la aplicación y robar los tokens de sesión y otra información sensible									
RIESGO DE LA VULNERABILIDAD									
- Un atacante que obtiene los tokens de sesión y otra información sensible puede suplantar la identidad del usuario y realizar acciones no autorizadas									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Se instaló en un dispositivo con alto privilegios (root) 2. Se inició sesión 3. Se usó una aplicación que permite explorar carpetas ocultas y de sistema 4. Se observó que se encontraba información de sesión que usa la aplicación. 5. Se identifico una Base de Datos sin encriptar: ✓ ZGMSCACHEPROPERTY ZNAME (VARCHAR): Nombre o identificador de la propiedad. ZVALUE (BLOB): Datos en diferentes formatos (JSON, Texto, Datos cifrados). ✓ ZGMSCACHEDOBJECT ZNAME (VARCHAR): Nombre del objeto (nombre descriptivo o identificador). ZBLOB (INTEGER): Identificador de un BLOB almacenado en otra tabla, o un dato serializado. ZUPDATEDDATE (TIMESTAMP): Fecha de actualización, útil para identificar datos recientes. ✓ ZGMSCACHEDOBJECTBLOB									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 36 de 132

ZDATA (BLOB): Este es el campo de datos sensibles, como tokens, sesiones o configuraciones.

CONSECUENCIAS

- Se logró identificar las tramas de comunicación entre la aplicación móvil y el servidor

REMEDIACIÓN

De manera general se puede recomendar según el tipo de archivo

Preferencias

1. Se recomienda usar encriptación al momento de almacenar las preferencias del usuario. Se puede seguir la recomendación según la guía oficial de Android en: <https://developer.android.com/topic/security/data>
2. En específico, <https://developer.android.com/topic/security/data#edit-shared-preferences> menciona usar preferencias encriptadas. Ejemplo:

```
String sharedPrefsFile = FILE_NAME;
SharedPreferences sharedPreferences = EncryptedSharedPreferences.create(
    sharedPrefsFile,
    mainKeyAlias,
    getApplicationContext(),
    EncryptedSharedPreferences.PrefKeyEncryptionScheme.AES256_SIV,
    EncryptedSharedPreferences.PrefValueEncryptionScheme.AES256_GCM
);

SharedPreferences.Editor sharedPrefsEditor = sharedPreferences.edit();
sharedPrefsEditor.apply();
```

Base de datos internas

1. Existen librerías que permiten encriptar el contenido de toda la base de datos. Por ejemplo, <https://guardianproject.info/code/sqlcipher/>
2. También se puede encriptar solamente los textos sensibles usando cualquier mecanismo seguro de cifrado. Para más información sobre en qué consiste este mecanismo de seguridad, se puede ver: <https://developer.android.com/guide/topics/security/cryptography>

Evidencia

```

1 preference_app_fid*FRUwaryjRzuTdzHLoQTsek
2
3 preference_app_onboarding
4
5 preference_app_valuef*E6ce3e7fc6dcb81dc9f3dcf06168916f217dec18daeb489b49c943e4d13496c8f1fbb198d89b74a852060d3140e96402be834adfeba39b6f7f3ed939ceb7349e0
6
7 preferences_token_key*
8
9 preference_app_remember_data
10
11 preference_app_card_number*
12
13
14 preference_app_id_user_code*
15
16 1094800027014
17
18 !preference_app_digital_token_done
19
20 3
21 preference_app_email_masked*j*****1@gmail.com
22
23
24 preference_app_email*jbp1601@gmail.com
25
26 #
27 preference_app_phone* 993752466
28
29
30 preference_app_phone_obfuscated* 99****466
31
32
33 !preference_app_card_number_masked*4697 **** **** 9447
34
35 6
36 preference_app_card_number_login*4697100201159447
37
38 #
39 preference_app_names* JOEL JOSH
40
41
42 preference_app_operator_network*0
43
44 #
45 preference_app_first_name*JOEL
46
47 3
48 -preference_app_registration_internet_shopping
49
50 -
51 preference_app_registration_fingerprint
52
53
54 (preference_app_registration_notification
55
56
57 preference_app_registration_use_abroad
58
59
60 preference_app_personeria
61
62
63 preference_app_doi
64
65 *72549026
66
67 9
68 preference_app_full_name*JOEL JOSH BUSTAMANTE PEREDO

```

Evidencia del almacenamiento de información de sesión en texto claro - Android

Evidencia

```

iPhone-de-Omar:~ root# ls -l /var/containers/Bundle/Application/
total 0
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 00AAE640-4326-4C92-8F6B-7B3CA48AA441/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 0E71EED9-2B3D-4ACD-B880-17A14D53BDCF/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 13AF0640-9482-4CCC-880A-BB2C12D9502B/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 1B5E73CC-12FC-4748-8DE8-DB7F3D36EAF0/
drwxr-xr-x 5 _installld _installld 160 Mar 30 12:26 1B8A551A-2B42-4D18-985A-88EB3B93D261/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 1D555F9A-2AE5-47AD-84DD-196656CCE073/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 2363219F-587B-46BC-B4ED-53A5C41FC2DD/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 24588B49-319E-496E-A4B0-8C6CB03F56B7/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 30BBAC77-C8D4-4F8A-933F-9B50ACEB9A30/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 3C3CAA05-9CB7-48BA-99FA-81155DB43824/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 4952153C-71BC-4DFF-9FEF-8FFCA1E7CCF6/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 52BA42C3-5990-422D-8D16-6F5C48D790C9/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 550C9951-2B20-42CE-A8DC-6FF2B281B0DF/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 5843CCD3-2E7F-4715-8C7F-9367B98B8916/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 64446B3B-6B78-4F3F-B05B-0C3401DFDDA5/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 653155D8-D553-4A9C-AF3C-0FB29F26C878/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 86B1654A-4E2F-4581-B53E-88D9A26394A1/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 8FBCD113-3BA6-40F2-9D04-1DEA8FEFCCE9/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 942A3738-1EBB-4947-81BB-703B50F148A5/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 A2905CD1-FF6D-4FC9-B403-3287F8F8C818/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 C074A4A1-3AE9-4521-A294-EB0D10D37D97/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 C59553C4-5255-4883-8FE6-CCF4406E155C/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 CB60A119-C527-4073-8AFE-F197AB3C4D45/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 CD2564E8-41E8-42DC-965E-49E0C370742C/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 DB735200-5D2F-40D6-9DD3-798BD7B1B49F/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 DD4E074B-3C10-4C3A-B7F0-4E3B22FB3151/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:45 DF10D02B-238B-4F7F-8AA3-5B150EC1E827/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 E4160518-BD66-4B60-B81B-F46ABE2B2BE9/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 EA534890-384A-47AE-A2D5-10CD76842E4E/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 F00C4DFC-6B47-4835-A1BD-DDA129A7BCA5/
drwxr-xr-x 6 _installld _installld 192 Mar 24 19:12 F448FCF7-593D-41B4-9A54-0F55ED589BC9/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 FD983FE4-7526-4C27-A357-E570C988BAA3/
drwxr-xr-x 5 _installld _installld 160 Mar 22 15:46 FE33315A-3197-4839-878A-185DCA27DE0B/
iPhone-de-Omar:~ root#

```

Evidencia del almacenamiento de información de sesión en texto claro - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 38 de 132

Evidencia

```
grep: ./Localizable.strings: binary file matches
grep: ./Frameworks/FirebaseCore.framework/FirebaseCore: binary file matches
grep: ./Frameworks/FBLPromises.framework/FBLPromises: binary file matches
grep: ./Frameworks/FirebaseInstallations.framework/FirebaseInstallations: binary file matches
grep: ./Frameworks/FirebaseAppDistribution.framework/FirebaseAppDistribution: binary file matches
grep: ./Frameworks/GoogleUtilities.framework/GoogleUtilities: binary file matches
grep: ./Frameworks/KeychainSwift.framework/KeychainSwift: binary file matches
grep: ./CajaMaynas: binary file matches
grep: ./Assets.car: binary file matches
iPhone-de-0mar:/var/containers/Bundle/Application/1B8A551A-2B42-4D18-985A-8BE83B93D261/CajaMaynas.app root#
```

Evidencia del almacenamiento de información de sesión en texto claro - iOS

Evidencia

```
iPhone-de-0mar:/var/containers/Bundle/Application/1B8A551A-2B42-4D18-985A-8BE83B93D261/CajaMaynas.app root# cat /var/mobile/Containers/Data/Application/94D44
9D-F364-40FD-A580-94E133431E6B/Library/Preferences/com.cajamaynas.app.2778T284C6.plist

?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN" "http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
  <key>com.google.Maps.GMSCoreLastVersion</key>
  <string>6.143.0</string>
  <key>com.google.Maps.GMSSDKLastVersion</key>
  <string>9.3.0</string>
  <key>kMapsSDKRealtimeLoggingCounterToPreviousLoggedTimeMsMapKey</key>
  <dict>
    <key>ApplicationProcessStarted</key>
    <integer>1743358566801</integer>
  </dict>
  <key>showOnboarding</key>
  <false/>
</dict>
</plist>
```

Evidencia del almacenamiento de información de sesión en texto claro - iOS

Evidencia

```
sqlite> PRAGMA table_info(ZGMSHCACHEPROPERTY);
PRAGMA table_info(ZGMSHCACHEDOBJECT);
PRAGMA table_info(ZGMSHCACHEDOBJECTBLOB);
0|Z_PK|INTEGER|0||1
1|Z_ENT|INTEGER|0||0
2|Z_OPT|INTEGER|0||0
3|ZTYPE|INTEGER|0||0
4|ZNAME|VARCHAR|0||0
5|ZVALUE|BLOB|0||0
0|Z_PK|INTEGER|0||1
1|Z_ENT|INTEGER|0||0
2|Z_OPT|INTEGER|0||0
3|ZTYPE|INTEGER|0||0
4|ZVERSION|INTEGER|0||0
5|ZBLOB|INTEGER|0||0
6|ZUPDATEDDATE|TIMESTAMP|0||0
7|ZNAME|VARCHAR|0||0
0|Z_PK|INTEGER|0||1
1|Z_ENT|INTEGER|0||0
2|Z_OPT|INTEGER|0||0
3|ZPARENT|INTEGER|0||0
4|ZDATA|BLOB|0||0
```

Evidencia del almacenamiento de información de sesión en texto claro - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 39 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	8.1
Subpuntuación de Impacto	5.3
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	8.1

5.8. Falta de Ofuscación de claves de API y datos sensibles en binario

Falta de Ofuscación de claves de API y datos sensibles en binario		RIESGO ALTO							
		CVSS	7.7						
Descripción	La exposición de claves de API y configuraciones de backend en texto claro dentro del binario representa riesgos significativos para la seguridad de la aplicación, incluyendo el uso no autorizado de servicios de terceros (como Google Maps o Firebase), acceso indebido a datos sensibles almacenados en la nube, suplantación de identidad de la aplicación en entornos de prueba o producción, y posibilidad de ataques dirigidos al backend.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante descarga la aplicación y utiliza herramientas de análisis estático (como strings, IDA Pro, Ghidra) para examinar el binario. Al no haber ofuscación, las claves de API y los datos sensibles se encuentran fácilmente en texto claro. - Un atacante podría ejecutar la aplicación en un emulador o un dispositivo roteado y utilizar herramientas de depuración o monitoreo de red para observar cómo se utilizan las claves de API y los datos sensibles, confirmando su validez y propósito.									
RIESGO DE LA VULNERABILIDAD									
- Un atacante podría utilizar las claves de Google Maps API para consumir cuotas del servicio de la organización, generando costos inesperados o incluso interrumpiendo el servicio para usuarios legítimos - Las claves de Firebase o Storage Bucket podrían permitir a un atacante leer, modificar o eliminar datos sensibles almacenados en la nube, comprometiendo la privacidad de los usuarios o la integridad de la información de la aplicación - Un atacante podría utilizar los identificadores de configuración (como PROJECT_ID) para hacerse pasar por la aplicación legítima en entornos de prueba o producción, potencialmente realizando acciones maliciosas en nombre de la aplicación									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Durante el análisis estático del binario de la aplicación CajaMaynas.ipa, se identificó la presencia de múltiples referencias explícitas a claves de API (APIKey, GoogleMapsAPIKey, GRPCAPIKey, entre otros), así como identificadores de configuración de backend como PROJECT_ID, STORAGE_BUCKET, y una clave real de Google API (AlzaSyDB9fq1rjzECaDehWcEPybpLT9kud1_wcQ).									
CONSECUENCIAS									
- Estos elementos encontrados en texto claro dentro del binario sin ninguna técnica de ofuscación o cifrado, lo cual permite su fácil extracción mediante herramientas de análisis como strings. - La presencia directa de estos datos sensibles evidencia una falta de protecciones adecuadas a nivel de código binario, lo cual facilita la ingeniería inversa.									

- Eliminar las claves de API y datos sensibles del código binario: Estas credenciales no deben estar directamente en el código de la aplicación.
- Utilizar mecanismos de almacenamiento seguro: Almacenar las claves y datos sensibles en un backend seguro y recuperarlos solo cuando sea necesario a través de mecanismos autenticados.
- Implementar ofuscación de código: Utilizar herramientas de ofuscación de código para Android (como ProGuard o DexGuard) para dificultar la ingeniería inversa y la extracción de información sensible del binario.
- Utilizar soluciones de gestión de secretos: Considerar el uso de servicios de gestión de secretos que permitan la rotación de claves y el acceso controlado.

[illegible]

Evidencia de la falta de ofuscación de claves de API y datos sensibles en binario - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 42 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Alto
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	7.7
Subpuntuación de Impacto	5.5
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	7.7

5.9. Falta de Protección contra Depuración

Falta de Protección contra Depuración		RIESGO ALTO							
		CVSS	7.7						
Descripción	La aplicación Caja Maynas fue ejecutada en un entorno con jailbreak, y al intentar la conexión mediante debugserver y lldb, se logró establecer sesión de depuración sin errores ni restricciones. Esto indica la ausencia de técnicas anti-debug, como ptrace(PT_DENY_ATTACH) o validaciones mediante sysctl, lo cual constituye una vulnerabilidad clasificada como M7: Insufficient Binary Protections								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante puede adjuntar un depurador (como lldb en iOS o gdb en Android) a la aplicación en ejecución en un dispositivo jailbreak/rootado o en un emulador. Esto le permite inspeccionar la memoria de la aplicación en tiempo real, examinar variables, rastrear la ejecución del código, entender la lógica de negocio, identificar posibles vulnerabilidades (como fallos de seguridad, errores de validación de entrada o lógica incorrecta), y observar cómo se manejan los datos sensibles.									
RIESGO DE LA VULNERABILIDAD									
- Un eventual atacante podría inspeccionar memoria en tiempo real (leer claves, tokens, estructuras internas), interceptar y modificar funciones usando lldb, Frida u otras herramientas. - Bypassar lógica de negocio, validaciones, o cifrado, directamente desde el runtime.									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Se realizó la instalación en un equipo con jailbreak. 2. Se realizó el análisis estático. 3. Se realizó validaciones sobre la depuración del sistema. 4. Se identificó que el aplicativo no tiene controles contra la depuración.									
CONSECUENCIAS									
- Pérdida de datos personales y financieros de los clientes - Acceso no autorizado a cuentas de clientes									
REMEDIACIÓN									
- Utilizar mecanismos como ptrace(PT_DENY_ATTACH) en iOS y técnicas similares en Android para prevenir la conexión de depuradores. - Verificar el entorno de ejecución para detectar signos de jailbreak/root y reaccionar apropiadamente (por ejemplo, cerrando la aplicación o deshabilitando funcionalidades sensibles). - Verificar la integridad del código en tiempo de ejecución para detectar modificaciones. - Evitar almacenar datos sensibles en memoria en texto plano y utilizar técnicas de cifrado adecuadas.									

Evidencia

```
debugserver-@(#)PROGRAM:LLDB  PROJECT:lldb-16.0.0
for arm64.
Attaching to process 88691...
Listening to port 1234 for a connection from *...
█
```

```
Last login: Sun Apr  6 11:47:55 on ttys004
omargavidia@Omars-MacBook-Air binario % lldb
```

```
(lldb) process connect connect://192.168.1.50:1234
█
```

Evidencia de la falta de Protección contra Depuración- iOS

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	7.7
Subpuntuación de Impacto	5.5
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	7.7

5.10. Exposición de archivos de configuración sensibles

Exposición de archivos de configuración sensibles		RIESGO ALTO							
		CVSS	7.5						
Descripción	Es una vulnerabilidad activa porque los archivos sensibles están accesibles en la aplicación de manera que un atacante podría aprovecharlos para robar información o hacer un uso indebido.								
	No es solo una "potencial" vulnerabilidad, sino que el hecho de que esos archivos sean accesibles sin medidas de seguridad adecuadas ya constituye una vulnerabilidad.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante con acceso físico a un dispositivo rooteado o con jailbreak puede navegar por el sistema de archivos de la aplicación y leer los archivos de configuración sensibles que no estén protegidos adecuadamente. - Un atacante puede descargar el paquete de la aplicación (APK o IPA) y utilizar herramientas de análisis estático para examinar su contenido. Si los archivos de configuración sensibles están incluidos directamente en el paquete sin cifrado o protección, pueden ser fácilmente extraídos.									
RIESGO DE LA VULNERABILIDAD									
- Los archivos de configuración podrían contener claves de API para servicios de terceros (como Google Maps, Firebase, redes sociales, etc.), permitiendo un uso no autorizado de estos servicios a expensas de la organización o con fines maliciosos. - Podrían revelarse contraseñas internas, tokens de acceso, claves de cifrado u otra información secreta utilizada por la aplicación para comunicarse con servidores o servicios.									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Durante las pruebas estáticas se logró identificar las rutas donde se encuentran los archivos: ✓ Exposición del archivo Info.plist Ruta: /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/Info.plist Ruta adicional: /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap sResources.bundle/GoogleMaps.bundle/Info.plist Ruta final: /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/Info.plist ✓ Exposición de los archivos de configuración de Google Maps Ruta: /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/ic_covid_medical_waypoint_ alert_night_32pt.png Ruta adicional: /Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/ic_covid_checkpoint_waypoi nt_alert_32pt.png									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 47 de 132

- ✓ Exposición de las claves de API de Google Maps (en el archivo oss_licenses_maps.txt.gz)
Ruta:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/oss_licenses_maps.txt.gz
- ✓ Exposición de archivos de almacenamiento de datos .mom y .momd (almacenamiento persistente)
Ruta:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCacheStorage.momd/Storage.mom
Ruta adicional:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCacheStorage.momd/StorageWithTileProto.mom
Ruta final:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCacheStorage.momd/StorageWithTileVersionID.mo
m
- ✓ Exposición de recursos gráficos y otros archivos no protegidos (imágenes y recursos visuales)
Rutas:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/measle_L.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/GMSSprites-0-2x.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/measle_X.png
- ✓ Exposición de archivos de licencias
Ruta:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/oss_licenses_maps.txt.gz
- ✓ Exposición de archivos de texto con configuraciones o recursos locales de Google Maps
Ruta:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/hr.lproj/GMSCore.strings
Ruta adicional:
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/GoogleMap
sResources.bundle/GoogleMaps.bundle/GMSCoreResources.bundle/hi.lproj/GMSCore.strings

CONSECUENCIAS

- Uso no autorizado de servicios de terceros, generando costos o interrupciones
- Acceso no autorizado a datos de usuario o de la aplicación a través de la infraestructura backend.

REMEDIACIÓN

- No incluir información sensible directamente en archivos de configuración dentro del paquete de la aplicación
- Almacenar la información sensible en un backend seguro y recuperarla solo cuando sea necesario a través de mecanismos autenticados
- Cifrar cualquier archivo de configuración que deba almacenarse localmente en la aplicación. Utilizar métodos de cifrado robustos y gestionar las claves de cifrado de forma segura (no incluirlas en el propio paquete de la aplicación)

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 48 de 132

Evidencia

```

/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/Info.plist
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
Info.plist
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//Info.plist
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/ic_covid_medical_waypoint_alert_night_32pt.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/ic_covid_checkpoint_waypoint_alert_32pt.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
oss_licenses_maps.txt.gz
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCacheStorage.momd/Storage.mom
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCacheStorage.momd/StorageWithTileProto.mom
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/measle_L.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/GMSSprites-0-2x.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/measle_X.png
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
oss_licenses_maps.txt.gz
/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app//GoogleMapsResources.bundle/GoogleMaps.bundle/
GMSCoreResources.bundle/hr.lproj/GMSCore.strings

```

Evidencia de la exposición de archivos de configuración sensibles - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 49 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	7.5
Subpuntuación de Impacto	4.7
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	7.5

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 50 de 132

5.11. Inadecuado proceso de time out

Inadecuado proceso de time out		RIESGO ALTO							
		CVSS	7.3						
Descripción	Durante las presentes pruebas se pudo identificar que el token de sesión tiene un tiempo de vida muy alto, por lo que a pesar de que la aplicación móvil se cierre sesión aún se puede realizar operaciones.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><td>N°</td><td>Aplicación Móvil</td><td>Sistema Operativo</td></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				N°	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
N°	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante podría interceptar el tráfico en la red y capturar múltiples peticiones, por lo que podría replicar operaciones a pesar de que la aplicación se cierre sesión por inactividad.									
RIESGO DE LA VULNERABILIDAD									
- Un eventual atacante puede realizar transferencias de dinero no autorizadas. - Un eventual atacante puede acceder a información confidencial de la cuenta bancaria de otros usuarios.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Se ingreso al sistema 2. Se captura las peticiones generadas al realizar diferentes operaciones 3. Luego de unos minutos de inactividad, el sistema se cierra de forma automática 4. Se puede visualizar que a pesar de haberse cerrado sesión de forma automática aún se puede seguir realizando operaciones.									
CONSECUENCIAS									
- Los clientes de la organización pueden sufrir un robo de identidad.									
REMEDIACIÓN									
- Reducir el tiempo de duración del token JWT, el tiempo de vida promedio debe de ser de 3-5 minutos									

JWT Decoder JWT Encoder

Paste a JWT below that you'd like to decode, validate, and verify.

Generate example

ENCODED VALUE

JSON WEB TOKEN (JWT)

Valid JWT

Invalid Signature

[eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ3c2VyRGF0YSI6IkNlYXVxNXBUEk1LCjYmYiojeCNDI5MzU3NTAsImV4Ci6MTCMzMAYmJlMECwiaWF0IjojNzQyOTM1ZnUwLjCjpc3MiOiJodHRwOi8vbG9jYWob3N0OjIwJmJEvIiwiaXYXkiOiJoahR0CDovL2xvY2FsaG9zdDoyMDIxLyJ9.nLfYPuQPg-fAtPw7i3hhNsLwP_-167Q1TySNBz_1U|](#)

DECODED HEADER

JSON CLAIMS TABLE

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

DECODED PAYLOAD

JSON CLAIMS TABLE

```

{
  "Us": "Wed Mar 28 2025",
  "nb": "15:49:10 GMT-0500",
  "exp": "1743022150",
  "iat": "1742935750",
  "iss": "http://localhost:2021/",
  "aud": "http://localhost:2021/"
}

```

Evidencia del inadecuado proceso de time out - Android

[illegible][illegible]

Evidencia del inadecuado proceso de time out - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 52 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	7.3
Subpuntuación de Impacto	3.4
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	7.3

5.12. Inyección de Código en Tiempo de Ejecución

Inyección de Código en Tiempo de Ejecución		RIESGO ALTO							
		CVSS	7.2						
Descripción	La ausencia de restricciones para el hooking dinámico permite que un atacante inyecte código malicioso o modifique el comportamiento de la aplicación en tiempo de ejecución.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante puede utilizar herramientas como Frida, Cydia Substrate (en iOS jailbreak) o Xposed Framework (en Android rooted) para interceptar y modificar el comportamiento de funciones críticas de la aplicación en tiempo de ejecución. Esto incluye funciones relacionadas con la autenticación, autorización, manejo de datos sensibles, criptografía, y comunicaciones de red. - Mediante el hooking, un atacante puede eludir las comprobaciones de seguridad implementadas en la aplicación. Por ejemplo, puede saltarse las validaciones de PIN/contraseña, deshabilitar la verificación de certificados SSL/TLS, o ignorar las protecciones contra manipulación del binario.									
RIESGO DE LA VULNERABILIDAD									
- Control total sobre el comportamiento de la aplicación en tiempo de ejecución - Capacidad de eludir cualquier mecanismo de seguridad implementado en la aplicación - Acceso no autorizado a funcionalidades y datos protegidos									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Se realizó la instalación en un equipo con jailbreak. 2. Se realizó el análisis estático. 3. Se realizó validaciones sobre la inyección de código en tiempo de ejecución.									
CONSECUENCIAS									
- Pérdida de datos personales y financieros de los usuarios - Acceso no autorizado a cuentas de usuario y realización de transacciones fraudulentas									
REMEDIACIÓN									
- La aplicación debe intentar detectar la presencia de herramientas de hooking como Frida o Cydia Substrate y reaccionar apropiadamente (por ejemplo, cerrándose o impidiendo funcionalidades sensibles). - Utilizar técnicas de ofuscación de código avanzadas de manera que dificulte la comprensión y manipulación del código por parte de un atacante, incluso si logra inyectar código. - Asegurarse de que el código de la aplicación no ha sido modificado durante la ejecución.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 55 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Cambiado
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	7.2
Subpuntuación de Impacto	2.7
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	7.2

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 56 de 132

5.13. Comunicación interceptada

Comunicación interceptada		RIESGO MEDIO							
		CVSS	6.5						
Descripción	Las aplicaciones seguras cuentan con un mecanismo para evitar la interceptación de la comunicación. Esto consiste en integrar un certificado de seguridad de la empresa en la aplicación para hacer que la comunicación sea segura sin que esta dependa de un certificado externo que permita que un atacante cambie el certificado externo por otro que a través de una herramienta y le posibilite capturar en texto plano la comunicación. Sin embargo, se encontró que no se cuenta con este mecanismo								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante podría conectarse a la misma red de un cliente y debido a la falta del “certificate pinning” puede realizar un ataque Man-in-the-Middle (MiTM) interceptando y descifrando la comunicación entre la aplicación móvil y el servidor.									
RIESGO DE LA VULNERABILIDAD									
- Un atacante puede robar credenciales de inicio de sesión, números de tarjeta de crédito, datos personales y otra información confidencial transmitida por la aplicación - Un atacante puede realizar transacciones fraudulentas utilizando la información robada									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de Identificación: 1. Se cambió el proxy global del dispositivo para conectarse a un equipo en la misma red local. Si hay vpn de por medio, el equipo (PC o Laptop) se conecta a la VPN, y el dispositivo no. 2. En el equipo se inició y configuró el software BurpSuite para el ataque de hombre en el medio 3. Se incorporó el certificado de BurpSuite como certificado del sistema del dispositivo 4. Al acceder a la aplicación y ejecutar cualquier llamada hacia los servicios web se logró interceptar las tramas de comunicación.									
CONSECUENCIAS									
- Se logró identificar las tramas de comunicación entre la aplicación móvil y el servidor									
REMEDIACIÓN									
1. Se recomienda implementar el mecanismo que evite la interceptación de la comunicación 2. Se cuenta con recomendaciones en la guía del desarrollo de Android los mecanismos para el aseguramiento a. Pinning https://developer.android.com/training/articles/security-ssl#Pinning Los mecanismos: • Trust Manager • OkHttp y CertificatePinner • Android Pinning Library • Entre otros									

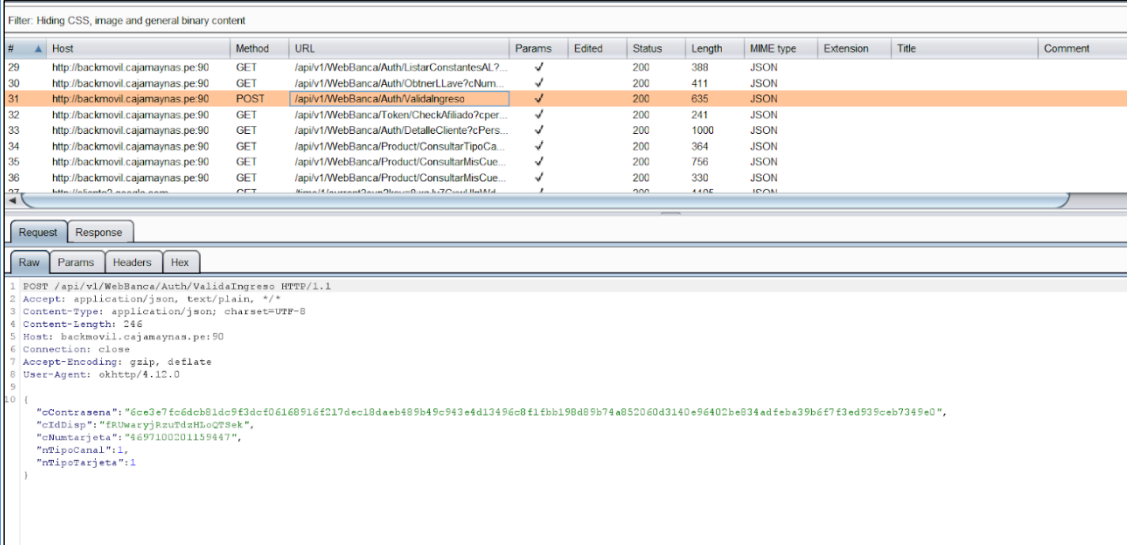
Sirven para implementar certificate pinning y donde se recomienda hacer la implementación para versiones inferiores a Android 9 y de la forma moderna. Esto está explicado en <https://ulvi-jabbarli.medium.com/ssl-pinning-in-android-apps-995f5b9c568>

b. Certificados clientes

<https://developer.android.com/training/articles/security-ssl#ClientCert>

“SSL también admite la noción de certificados de cliente que permiten al servidor validar la identidad de un cliente... las técnicas involucradas son similares a la especificación de un TrustManager personalizado.”

Evidencia



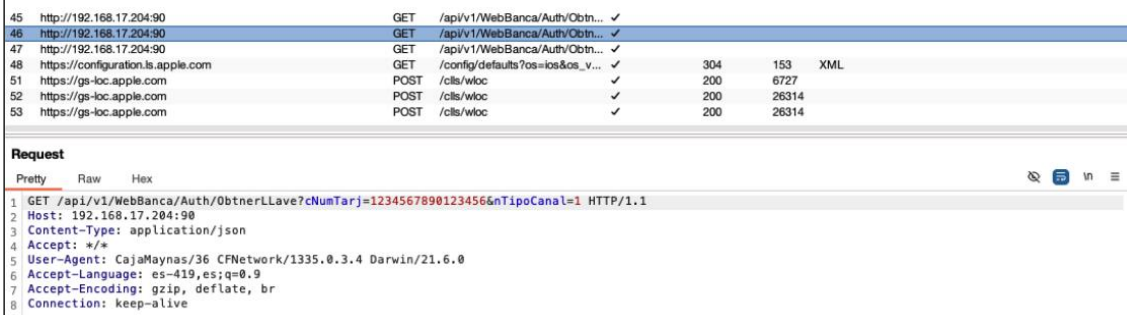
#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title	Comment
29	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Auth/ValidaIngreso		✓	200	388	JSON			
30	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Auth/ValidaIngreso		✓	200	411	JSON			
31	http://backmovil.cajamaynas.pe:90	POST	/api/v1/WebBanca/Auth/ValidaIngreso		✓	200	635	JSON			
32	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Auth/ValidaIngreso		✓	200	241	JSON			
33	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Auth/ValidaIngreso		✓	200	1000	JSON			
34	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Product/ConsultarTipoCa...		✓	200	364	JSON			
35	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Product/ConsultarMisCue...		✓	200	756	JSON			
36	http://backmovil.cajamaynas.pe:90	GET	/api/v1/WebBanca/Product/ConsultarMisCue...		✓	200	330	JSON			

```

1 POST /api/v1/WebBanca/Auth/ValidaIngreso HTTP/1.1
2 Accept: application/json, text/plain, */*
3 Content-Type: application/json; charset=UTF-8
4 Content-Length: 246
5 Host: backmovil.cajamaynas.pe:90
6 Connection: close
7 Accept-Encoding: gzip, deflate
8 User-Agent: okhttp/4.12.0
9
10 {
  "Contraseña": "6ce3e7f6dcb61dc9f3dcf06168916f217dec18daeb489b49c943e4d13496c0f1fbb198d85b74a852060d3140e96402be34adfeba39b6ef73ed935ceb7349e0",
  "CidDisp": "F0MwajykRutdaHb0QF9ek",
  "CuentaJeta": "4697100001159447",
  "nTipoCanal": 1,
  "nTipoTarjeta": 1
}
  
```

Evidencia de la comunicación interceptada - Android

Evidencia



#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title	Comment
45	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/ObtnerLLave?cNumTarj=12345678901234566nTipoCanal=1		✓	200	304	153	XML		
46	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/ObtnerLLave?cNumTarj=12345678901234566nTipoCanal=1		✓	200	200	6727			
47	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/ObtnerLLave?cNumTarj=12345678901234566nTipoCanal=1		✓	200	200	26314			
48	https://configuration.ls.apple.com	GET	/config/defaults?os=ios&os_v...		✓	200	200	26314			
51	https://gs-loc.apple.com	POST	/cls/wloc		✓	200	200	26314			
52	https://gs-loc.apple.com	POST	/cls/wloc		✓	200	200	26314			
53	https://gs-loc.apple.com	POST	/cls/wloc		✓	200	200	26314			

```

1 GET /api/v1/WebBanca/Auth/ObtnerLLave?cNumTarj=12345678901234566nTipoCanal=1 HTTP/1.1
2 Host: 192.168.17.204:90
3 Content-Type: application/json
4 Accept: */*
5 User-Agent: CajaMaynas/36 CFNetwork/1335.0.3.4 Darwin/21.6.0
6 Accept-Language: es-419,es;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9
  
```

Evidencia de la comunicación interceptada - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 58 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	6.5
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	6.5

5.14. Inadecuada gestión de sesiones: Envío de peticiones sin token JWT

Inadecuada gestión de sesiones: Envío de peticiones sin token JWT		RIESGO MEDIO							
		CVSS	6.5						
Descripción	La aplicación móvil en la petición donde se envía el SMS de verificación carece de un mecanismo de gestión de sesiones adecuado. Esto significa que una vez que un usuario inicia sesión, el sistema no mantiene un registro activo de su identidad en dicha petición. Un atacante podría aprovechar esta vulnerabilidad para: ✓ Suplantar la identidad de un usuario ✓ Enviar SMS spam a diferentes clientes de la organizacion								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante informático enviar el SMS de verificación a otro número. - Un atacante informático podría enviar SMS de forma masiva a uno o múltiples clientes de la organización.									
RIESGO DE LA VULNERABILIDAD									
- Un eventual atacante podría realizar transacciones no autorizadas.									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: - Se ingreso al sistema de información - Al momento de autorizar una transferencia se identificó la siguiente petición: <pre>POST /api/v1/WebBanca/Token/GuardarSMS HTTP/1.1 Accept: application/json, text/plain, */* Content-Type: application/json; charset=UTF-8 Content-Length: 114 Host: backmovil.cajamaynas.pe:90 Connection: close Accept-Encoding: gzip, deflate User-Agent: okhttp/4.12.0 {"cDescripcion":"2","cID":"1094800027014","cID_Dispositivo":"duqwOz1zREamPFLusl4lkX","cOperacion":"2","nEstado":1}</pre> - Se pudo visualizar que no cuenta con ningún token JWT de sesión.									
CONSECUENCIAS									
- Identificación de usuarios del personal de la organización lo que podría llevar a ataques más sofisticados.									

REMEDIACIÓN

Se recomienda realizar una gestión de sesiones

1. Utilizar un mecanismo seguro para identificar y rastrear las sesiones de los usuarios, como cookies, tokens JWT, etc.
2. Establecer un tiempo de vida limitado para las sesiones y renovarlas periódicamente
3. Invalidar las sesiones cuando un usuario cierra sesión

Evidencia

Request

Raw Params Headers Hex

```
POST /api/v1/WebBanca/Token/GuardarSMS HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
Content-Length: 114
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0

{"cDescripcion":"2","cID":"1094800027014","cID_Dispositivo":"duqwOz1zREamPFLusI41kX","cOperacion":"2","nEstado":1}
```

Evidencia de la Inadecuada gestión de sesiones: Envío de petición sin token JWT - Android

Evidencia

Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Content-Length: 91
Connection: close
Content-Type: application/json
Date: Tue, 25 Mar 2025 21:42:39 GMT
Server: Kestrel
api-supported-versions: 1.0

{"cDescResultado":"Se registro SMS","nResultado":1,"cValorResultado":"Se envio el mensaje"}
```

Evidencia de la Inadecuada gestión de sesiones: Envío de petición sin token JWT - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 61 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Ninguno
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Alto
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	6.5
Subpuntuación de Impacto	3.6
Subpuntuación de Explotabilidad	2.8
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	6.5

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 62 de 132

5.15. Permisos Excesivos en el Entitlements.plist

Permisos Excesivos en el Entitlements.plist		RIESGO MEDIO							
		CVSS	6.5						
Descripción	La aplicación no cuenta con una firma válida que permita extraer y revisar los entitlements. Esto impide validar si existen permisos excesivos o peligrosos, lo cual representa una mala configuración de seguridad bajo el principio de transparencia mínima requerida para auditoría.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante que obtiene el archivo IPA de la aplicación no puede verificar de manera confiable los entitlements declarados debido a la firma inválida. Esto significa que podría haber permisos peligrosos o excesivos concedidos a la aplicación sin que puedan ser fácilmente identificados mediante un análisis estándar. - Ante la imposibilidad de revisar los entitlements de forma directa, un atacante se verá obligado a realizar una ingeniería inversa más profunda del binario para inferir qué permisos se están utilizando y si existen funcionalidades que sugieran el uso de permisos peligrosos no evidentes.									
RIESGO DE LA VULNERABILIDAD									
- La imposibilidad de revisar el archivo Entitlements.plist debido a la falta de una firma válida representa un riesgo significativo, ya que impide verificar si la aplicación solicita permisos excesivos o peligrosos como acceso irrestricto a la red, desactivación del sandbox o uso compartido de llaveros, lo cual podría comprometer la confidencialidad e integridad de los datos del usuario; además, esta falta de visibilidad limita la capacidad de auditar adecuadamente la seguridad de la aplicación									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Se realizó la instalación en un equipo con jailbreak. 2. Se realizó el análisis estático. 3. Se realizó validaciones sobre los permisos excesivos que deben tener.									
CONSECUENCIAS									
- Dificultad para garantizar la privacidad del usuario debido a la falta de transparencia en los permisos - Riesgo de que la aplicación acceda a datos sensibles sin una justificación clara o sin el conocimiento del usuario									
REMEDIACIÓN									
- El primer paso crucial es asegurarse de que la aplicación esté firmada correctamente con un certificado válido. Esto permitirá la extracción y revisión del archivo entitlements.plist - Revisar y minimizar los entitlements en el archivo entitlements.plist, una vez que se puede acceder al archivo, auditar cuidadosamente cada entitlement solicitado y eliminar aquellos que									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 63 de 132

no sean estrictamente necesarios para la funcionalidad de la aplicación. Aplicar el principio de privilegio mínimo.

Evidencia

```
omargavidia@Omars-MacBook-Air CajaMaynas.app % codesign -d --entitlements :- CajaMaynas

Executable=/Users/omargavidia/Documents/Caja_Maynas/CajaMaynas/Payload/CajaMaynas.app/CajaMaynas
CajaMaynas: no signature
warning: Specifying ':' in the path is deprecated and will not work in a future release
```

Evidencia de los permisos excesivos en el Entitlements.plist- iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 64 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	6.5
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	6.5

5.16. Copia de seguridad de la aplicación habilitada

Copia de seguridad de aplicación habilitada		RIESGO MEDIO							
		CVSS	6.5						
Descripción	Una copia de seguridad permite guardar todo tipo de información almacenada en nuestro dispositivo móvil o en las aplicaciones usadas, y tenerlas a disposición en un espacio de almacenamiento alternativo. Si bien esto es importante para evitar pérdida de datos, también debe considerarse los riesgos que implican almacenar información sensible en las copias de seguridad. En Android, una aplicación puede indicar si permite que se haga una copia de seguridad de sus datos a través del atributo [android: allowBackup] el cual debe establecerse de manera explícita, es decir, no debe dejarse sin especificar. Si se establece en true, o incluso, si no se especifica, se establece en true. Esto permite que cualquier persona haga una copia de seguridad de los datos de su aplicación a través de adb (Android Debug Bridge que es una herramienta de línea de comandos versátil que permite comunicarse con el dispositivo). Permite a los usuarios que han habilitado la depuración USB copiar los datos de la aplicación fuera del dispositivo. Una vez realizada la copia de seguridad, el usuario puede leer todos los datos de la aplicación. Y a su vez le permite la restauración de los datos de la aplicación a partir de esa copia de seguridad. Después de una restauración, las aplicaciones asumen que los datos, los permisos de archivos y los permisos de directorio fueron creados por la propia aplicación. La configuración allowBackup = "false" excluye a una aplicación tanto de la copia de seguridad como de la restauración.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android							
ESCENARIOS DE EXPLOTACIÓN									
- Un malware instalado en el dispositivo puede realizar una copia de seguridad de la aplicación sin el conocimiento del usuario y enviar los datos a un servidor remoto controlado por el atacante.									
RIESGO DE LA VULNERABILIDAD									
- En caso si almacenase información sensible como contraseñas, credenciales, datos privados, estos podrían ser respaldados y restaurados en otro dispositivo - Esto podría llevar a un mal uso de estos datos para mayores ataques.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de Identificación: 1. Se aplicó la ingeniería de reversa del APK publicado, y se encontró el archivo AndroidManifest.xml. 2. Se detectó la especificación explícita en al archivo AndroidManifest.xml permitiendo la copia de seguridad.									
CONSECUENCIAS									
- Mal uso de información privada									

REMEDIACIÓN

1. Se recomienda colocar en false el atributo allowBackup. Debería quedar así
android:allowBackup="false"

Para mayor referencia:

- <https://developer.android.com/guide/topics/manifest/application-element>
- <https://developer.android.com/reference/android/R.attr#allowBackup>
- <https://stackoverflow.com/questions/12648373/what-is-androidallowbackup>

Evidencia

Evidencia de la copia de seguridad de la aplicación habilitada - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 67 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	6.5
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	6.5

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 68 de 132

5.17. Ausencia de controles de PREVENCIÓN DE USO en dispositivos con privilegios de superusuario

Ausencia de controles de PREVENCIÓN DE USO en dispositivos con privilegios de superusuario		RIESGO MEDIO							
		CVSS	5.3						
Descripción	Se pudo instalar la aplicación en un dispositivo con privilegios ROOT y se pudo hacer uso de la aplicación sin restricciones lo cual permite la elaboración de ataques de mayor elaboración como acceder a datos sensibles del usuario almacenados en base de datos internas.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante informático puede manipular información de la aplicación móvil si es que accede físicamente al dispositivo móvil.									
RIESGO DE LA VULNERABILIDAD									
- Instalación de la aplicación a móvil en dispositivos celulares manipulados por un atacante informático. - Manipulación de información almacenada en el dispositivo celular asociado a la aplicación móvil.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> Las aplicaciones según el grado de sensibilidad de la información que pueda almacenarse en el dispositivo deben contar con controles que impidan a un usuario hacer uso de la aplicación si el sistema operativo Android y/o iOS está alterado con un procedimiento que le otorgue a un atacante privilegios elevados de acceso y autorización conocidos como privilegios root. Se pudo instalar la aplicación en un dispositivo con tales privilegios y usarla sin problemas.									
CONSECUENCIAS									
- Se verificó que es posible instalar la aplicación móvil que cuenta con privilegios ROOT - Se verificó que es posible instalar la aplicación móvil que cuenta con jailbreak									
REMEDIACIÓN									
<u>Para Android:</u> - Desde la configuración de Google Play, excluir los dispositivos que no cumplan con no ser roteados para prevenir que la aplicación se instale. Para la guía de exclusión, se puede consultar: https://support.google.com/googleplay/android-developer/answer/7353455?hl=en#zippy=%2Cmanage-excluded-devices-based-on-android-compatibility - Desde la lógica de la aplicación, realizar una verificación al iniciar el programa para evitar que se continúe con el flujo de la aplicación donde se encuentre alguna evidencia de que el teléfono esté roteado. Por ejemplo, esto se puede implementar teniendo como ejemplo la librería rootbeer o siguiendo estos pasos: - Implementar la clase RootUtil									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 69 de 132

```

public class RootUtil {
    public static boolean isDeviceRooted() {
        return checkRootMethod1() || checkRootMethod2() || checkRootMethod3();
    }
    private static boolean checkRootMethod1() {
        String buildTags = android.os.Build.TAGS;
        return buildTags != null && buildTags.contains("test-keys");
    }
    private static boolean checkRootMethod2() {
        String[] paths = { "/system/app/Superuser.apk", "/sbin/su", "/system/bin/su", "/system/xbin/su",
"/data/local/xbin/su", "/data/local/bin/su", "/system/sd/xbin/su", "/system/bin/failsafe/su", "/data/local/su" };
        for (String path : paths) { if (new File(path).exists()) return true; }
        return false;
    }
    private static boolean checkRootMethod3() {
        Process process = null;
        try {
            process = Runtime.getRuntime().exec(new String[] { "/system/xbin/which", "su" });
            BufferedReader in = new BufferedReader(new InputStreamReader(process.getInputStream()));
            if (in.readLine() != null) return true;
            return false;
        } catch (Throwable t) {
            return false;
        } finally {
            if (process != null) process.destroy();
        }
    }
}

```

- b. Implementar un activity que use la clase indicada en la parte superior. Debe ser utilizada al inicio de la aplicación (el primer Activity que se ejecuta).
- c. Configurar AndroidManifest para que el activity indicado valide si el teléfono está rooteado.

```

<activity
    android:label="My App"
    android:name="[NOMBRE DEL ACTIVITY CON EL QUE INICIA LA APLICACIÓN]"
    label="@string/app_name">

    <intent-filter>
        <action android:name="android.intent.action.MAIN" />
        <category android:name="android.intent.category.LAUNCHER" />
    </intent-filter>
</activity>

```

Para iOS:

- Utilizar múltiples técnicas para identificar dispositivos jailbreak, como la búsqueda de archivos y directorios específicos (/var/mobile/Library/Preferences), la verificación de la presencia de aplicaciones o binarios comunes en entornos jailbreak (Cydia, Substitute), la comprobación de esquemas de URL personalizados utilizados por herramientas de jailbreak, y la detección de entornos de depuración inusuales.
- Una vez que se detecta un dispositivo jailbreak, la aplicación debe reaccionar de manera segura. Las posibles respuestas incluyen:
 - Mostrar una advertencia al usuario.
 - Deshabilitar ciertas funcionalidades sensibles.
 - Impedir el inicio de la aplicación.
 - Limitar las interacciones con el servidor.

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 70 de 132

- La detección de jailbreak debe ser parte de una estrategia de seguridad en profundidad que incluya ofuscación de código, protección contra depuración, verificación de integridad del binario y otras técnicas.
- Las técnicas de jailbreak evolucionan, por lo que es importante mantener actualizadas las medidas de detección de la aplicación.

Evidencia

Root Checker Basic

VERIFY ROOT
UPGRADES
RANKINGS
ROOT BASI



Congratulations! Root access is properly installed on this device!

Device: SM-A305G
Android Version: 9
Date and Time: 3/16/25 10:49 PM

Advanced Root Checker



Adds: Customized assistance about the most important aspects of root status.

UPGRADE

Global Samsung SM-A305G Root Statistics



Ease of Root Install Rank: **10022**
Root Access Available: **Yes**
Root Install Difficulty: **Hard**
Top Reason to Root: *Requires Advanced Root purchase*
Manufacturer Ease of Root Install Rank: **5**

MORE DETAILS

Advanced Root Checker
Root Account Status



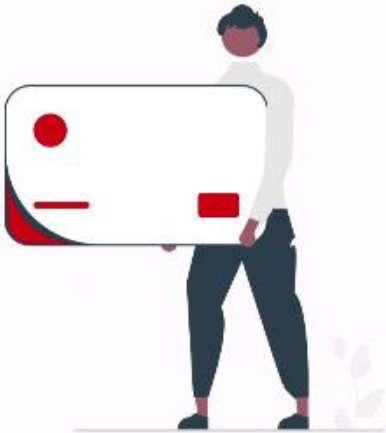
[Blurred text]

UPGRADE

Evidencia de la ausencia de controles de prevención de uso en dispositivos con privilegios de superusuario root - Android

Evidencia

Omitir



Bienvenido a la Banca Móvil

Podrás realizar pagos de créditos, pagos de servicios, transferencias y mucho más.

Evidencia de la ausencia de controles de prevención de uso en dispositivos con privilegios de superusuario root - Android

Documento con información confidencial

Evidencia



Número de tarjeta

Clave web

☐ Recordar datos



Ingresar

¿Olvidaste tu contraseña?



¡Afíliate a la banca digital!



Bloqueo de tarjeta



Token digital



Contáctanos



Ubícanos

Evidencia de la ausencia de controles de prevención de uso en dispositivos con privilegios de superusuario root - Android

Documento con información confidencial

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 73 de 132

Evidencia

```

/-----\
|  _  |   Frida 16.7.0 - A world-class dynamic instrumentation toolkit
| (  ) |
|  _  |   Commands:
> _  |   help      -> Displays the help system
/_/  |   object?   -> Display information about 'object'
. . . .   exit/quit -> Exit
. . . .
. . . .   More info at https://frida.re/docs/home/
. . . .
. . . .   Connected to iPhone (id=4fcd718b36cae23ab983574f84a96ff059f4a243)

[iPhone::CajaMaynas ]-> Interceptor.attach(Module.findExportByName(null, "stat"), {
  onEnter: function(args) {
    console.log("Stat called on: " + Memory.readUtf8String(args[0]));
  }
});
{}
[iPhone::CajaMaynas ]-> Stat called on: /var/mobile/Containers/Data/Application/94D44E9D-F364-40FD-A580-94E133431E6B

```

Evidencia de la ausencia de medidas Anti-Jailbreak- iOS

Evidencia

```

omargavidia@Omars-MacBook-Air binario % ssh root@192.168.1.39

(root@192.168.1.39) Password for root@iPhone-de-Omar:
iPhone-de-Omar:~ root# ls /var/mobile/Library/Preferences | grep cydia

iPhone-de-Omar:~ root# ls /var/mobile/Library/Preferences | grep sileo

iPhone-de-Omar:~ root# ls /var/mobile/Library/Preferences | grep palera1n

iPhone-de-Omar:~ root# ls /var/mobile/Library/Preferences | grep Zebra

```

Evidencia de la ausencia de medidas Anti-Jailbreak- iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 74 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.3
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.3

5.18. Múltiples vulnerabilidades en bibliotecas de terceros y dependencias

Mltiples vulnerabilidades en bibliotecas de terceros y dependencias		RIESGO MEDIO							
		CVSS	5.6						
Descripción	Se encontró que: la versión desactualizada de libz (1.2.12) contiene vulnerabilidades de desbordamiento de enteros que podrían permitir la ejecución de código remoto, mientras que las antiguas versiones de Firebase (todas en 1.0.0) probablemente contienen múltiples fallos de seguridad relacionados con la autenticación, almacenamiento de datos y comunicaciones con servidores, que han sido corregidos en versiones posteriores. Además, bibliotecas como KeychainSwift en versión 1.0.0 podrían implementar métodos obsoletos de encriptación y almacenamiento seguro, poniendo en riesgo información sensible de los usuarios.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Fallos en el almacenamiento de datos podrían permitir a un atacante modificar o acceder a datos de otros usuarios o datos sensibles de la aplicación sin la debida autorización - Si la biblioteca utiliza métodos de encriptación débiles o almacenamiento inseguro, un atacante con acceso al dispositivo (físico o remoto a través de malware) podría ser capaz de descifrar o extraer información sensible almacenada en el Keychain (como contraseñas, tokens de autenticación)									
RIESGO DE LA VULNERABILIDAD									
- Un atacante podría ejecutar código malicioso en el dispositivo del usuario a través de la vulnerabilidad en libz, obteniendo control total sobre el dispositivo. - Un atacante podría acceder a las cuentas de los usuarios sin las credenciales correctas debido a fallos en la autenticación de Firebase - Un atacante podría leer, modificar o eliminar datos privados de los usuarios almacenados en Firebase o protegidos por KeychainSwift									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Durante las pruebas estáticas se logró identificar que la librería libz, firebase y KeychainSwift presentan vulnerabilidades asociadas a su versión instalada en el sistema.									
CONSECUENCIAS									
- Ejecución de código remoto podría permitir el control completo del dispositivo - Acceso no autorizado a grandes cantidades de datos de usuario.									
REMEDIACIÓN									
- Actualizar las librerías de terceros que se encontraron sin actualizar, ya que se expone el sistema a vulnerabilidades conocidas y ampliamente documentadas que podrían ser explotadas por atacantes									

Evidencia				
Tabla de Vulnerabilidades Conocidas en Bibliotecas				
Biblioteca	Versión Actual	Tipo	Vulnerabilidades Conocidas	Recomendación
libz.1.dylib	1.2.12	Terceros	CVE-2022-37434 (desbordamiento de enteros). Posibles problemas de compresión/descompresión	Actualizar a 1.2.13
FirebaseCore.framework	1.0.0	Terceros	Múltiples vulnerabilidades de seguridad. Problemas de autenticación Posible exposición de datos	Actualizar a versión 10.x.x
FirebaseCoreInternal.framework	1.0.0	Terceros	Vulnerabilidades heredadas de Firebase. Posibles fallos en el manejo de datos internos	Actualizar a versión 10.x.x
FirebaseAppDistribution.framework	1.0.0	Terceros	Problemas de distribución de aplicaciones. Posible manipulación de paquetes	Actualizar a versión 10.x.x
FirebaseInstallations.framework	1.0.0	Terceros	Posibles fallos en instalación y registro. Vulnerabilidades en la gestión de tokens	Actualizar a versión 10.x.x
GoogleUtilities.framework	1.0.0	Terceros	Vulnerabilidades asociadas al ecosistema Firebase. Problemas de manejo de datos	Actualizar a versión 7.12.0
FBLPromises.framework	1.0.0	Terceros	Posibles problemas de gestión asíncrona. Vulnerabilidades de memoria	Actualizar a versión 2.3.1
KeychainSwift.framework	1.0.0	Terceros	Vulnerabilidades potenciales en almacenamiento seguro- Métodos antiguos de encriptación	Actualizar a versión 20.0.0

Evidencia de las múltiples vulnerabilidades en bibliotecas de terceros y dependencias - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 77 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.6
Subpuntuación de Impacto	3.4
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.6

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 78 de 132

5.19. Debilidades en el protocolo SSL/TLS

Debilidades en el protocolo SSL/TLS		RIESGO MEDIO							
		CVSS	5.4						
Descripción	El binario contiene la clave NSAllowsArbitraryLoads, lo que indica que la aplicación está configurada para permitir conexiones no seguras (sin TLS o sin validación de certificado), comprometiendo la confidencialidad e integridad de las comunicaciones.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante que se encuentre en la misma red Wi-Fi pública que el usuario puede interceptar la comunicación entre la aplicación y el servidor. Al estar NSAllowsArbitraryLoads habilitado, la aplicación podría permitir conexiones sin cifrado TLS o sin una validación estricta de los certificados del servidor, lo que permite al atacante ver y potencialmente modificar los datos transmitidos en texto plano. - Si la red local del usuario ha sido comprometida un atacante dentro de esa red puede realizar ataques MitM de manera similar, interceptando la comunicación no segura.									
RIESGO DE LA VULNERABILIDAD									
- Cualquier información personal, financiera o de otro tipo que la aplicación transmita podría ser interceptada y robada por el atacante									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Se identifico mediante el análisis estático del IPA. 2. Se realizó el análisis. 3. Se identificó se encuentra configurado la clave NSAllowArbitraryLoads lo cual permitiría el envío de información sin validación de certificados.									
CONSECUENCIAS									
- Pérdida de datos personales y financieros de los usuarios - Acceso no autorizado a cuentas de usuario - Realización de transacciones fraudulentas									
REMEDIACIÓN									
- Eliminar la clave NSAllowsArbitraryLoads del archivo Info.plist o establecer su valor en NO (o su equivalente booleano). Esto forzará a la aplicación a utilizar conexiones seguras por defecto - Implementar TLS (Transport Layer Security) para todas las comunicaciones sensibles con el servidor. Asegurarse de utilizar versiones seguras de TLS (TLS 1.2 o superior) y configuraciones de cifrado fuertes - Realizar una validación estricta de los certificados del servidor (Certificate Pinning). Esto asegura que la aplicación solo confíe en los certificados esperados y evita ataques MitM incluso si un atacante logra obtener un certificado aparentemente válido.									

Evidencia

NSAllowsArbitraryLoads
@"NSURLSession"16@?0@"<NSURLSessionDelegate">"8
com.google.GTMSessionFetcherNSURLSessionDelegateQueue
v32@?0@"NSURLSessionTask"8@"GMSx_GTMSessionFetcher"16^B24
So12NSURLSessionC
T@"NSURLSession",&,V_session
T@"NSURLSessionTask",R,V_sessionTask
T@"NSURLSession",&
T@"NSURLSessionConfiguration",&,V_configuration
NSURLSessionDelegate
v32@0:8@"NSURLSession"16@"NSError"24
v40@0:8@"NSURLSession"16@"NSURLAuthenticationChallenge"24@?<v@?q@"NSURLCredential">32
v24@0:8@"NSURLSession"16
@"NSURLSession"
@"NSURLSessionConfiguration"
@"NSURLSessionTask"
(myenv) omargavidia@0mars-MacBook-Air CajaMaynas.app %

Evidencia de las debilidades del protocolo SSL/TLS - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 80 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.4
Subpuntuación de Impacto	2.7
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.4

5.20. Exposición de datos sensibles a través de propiedades de accesibilidad

Exposición de datos sensibles a través de propiedades de accesibilidad		RIESGO MEDIO							
		CVSS	5.4						
Descripción	Se hace referencia a una serie de métodos que tienen que ver con cómo la aplicación maneja los datos en memoria, los archiva y los observa. Los métodos estar involucrados en el almacenamiento y la exposición de datos sensibles sin las adecuadas medidas de seguridad Exposición de Datos Sensibles en Métodos de Accesibilidad: <pre>setAccessibilityLabel: setAccessibilityTraits: setAccessibilityHint: setAccessibilityValue:</pre> Descripción: Estos métodos están asignando datos sensibles como contraseñas, números de tarjetas de crédito e información personal a las propiedades de accesibilidad, estando accesibles para herramientas o usuarios sin restricciones adecuadas. La configuración y manipulación de datos sensibles a través de las propiedades de accesibilidad (accessibilityLabel, accessibilityValue, etc.) sin aplicar mecanismos de protección se considera una vulnerabilidad de "Insecure Data Exposure".								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante puede utilizar las propias herramientas de accesibilidad integradas en el sistema operativo (como VoiceOver en iOS o TalkBack en Android) para leer el contenido de la pantalla y los elementos interactivos de la aplicación. Si los datos sensibles se asignan a las propiedades de accesibilidad, estas herramientas los leerán en voz alta o los mostrarán de manera accesible, permitiendo que el atacante los capture. - Un software malicioso instalado en el dispositivo podría interactuar con las APIs de accesibilidad para leer el contenido de la pantalla, incluyendo los datos sensibles expuestos a través de las propiedades de accesibilidad. También podría grabar la pantalla mientras un usuario interactúa con la aplicación, capturando la información sensible leída por las herramientas de accesibilidad									
RIESGO DE LA VULNERABILIDAD									
- Un atacante podría escuchar o leer las contraseñas mientras el usuario interactúa con los campos de inicio de sesión o configuración. - Los detalles de las tarjetas de crédito mostrados o procesados por la aplicación podrían ser capturados a través de las herramientas de accesibilidad.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Se identifico mediante el análisis estático del IPA. 2. Se realizó el análisis. 3. Se logró obtener datos sensibles expuestos.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 82 de 132

setAccessibilityLabel:
setAccessibilityTraits:
setAccessibilityHint:
setAccessibilityValue

CONSECUENCIAS

- Pérdida de datos personales y financieros de los usuarios
- Acceso no autorizado a cuentas de usuario
- Realización de transacciones fraudulentas

REMEDIACIÓN

- Evitar asignar datos sensibles directamente a las propiedades de accesibilidad (accessibilityLabel, accessibilityValue, accessibilityHint, accessibilityTraits).
- Utilizar descripciones de accesibilidad que proporcionen contexto y funcionalidad, pero que no revelen información sensible. Por ejemplo, en lugar de asignar la contraseña directamente al accessibilityValue, se podría indicar "Campo de contraseña".
- Implementar mecanismos de seguridad específicos para la visualización y el manejo de datos sensibles en la interfaz de usuario, como el uso de campos de texto seguros (que oscurecen la entrada) y la limitación de la exposición de información confidencial.

Evidencia

```

Frida 16.7.0 - A world-class dynamic instrumentation toolkit

Commands:
  help           -> Displays the help system
  object?       -> Display information about 'object'
  exit/quit     -> Exit

More info at https://frida.re/docs/home/

Connected to iPhone (id=4fcd718b3cae23ab983574f84a96ff859f4a243)

iPhone::CajaMaynas ]-> console.log(Object.keys(Object.getPrototypeOf(CajaMaynas.prototype).constructor.prototype));
Object: {__NSGenericDeallocationHandler, __NSAtom, __NSZombie, __NSMessageBuilder, __ISOOverlayEmbossedFolder, __ISEmbossedSmartFolder, __ISEmbossedFolder, __JSExport, __TtCsi2_SwiftO
bject, __TtC10CajaMaynasP33_75E80E0D020F0D2F8678BBAA2E8105F19ResourceBundleClass, CajaMaynas.ShareAccountFormatter, CajaMaynas.OtherBanksTransferInteractor, CajaM
aynas.LimitSettingsInteractor, CajaMaynas.CreditPrendiarioInteractor, CajaMaynas.ConfirmThirdPropertyRenewalInteractor, CajaMaynas.UserDefaultsManager, CajaMaynas
.KeychainLoadHash, CajaMaynas.OwnCreditsPresenter, CajaMaynas.MyProductsInteractor, CajaMaynas.HomeInteractor, CajaMaynas.SelectCreditAccountCancelPresenter, CajaM
aynas.ConfirmTurnShippingPresenter, CajaMaynas.DetailsIncreaseCapitalInteractor, CajaMaynas.ConfirmServicePaymentInteractor, CajaMaynas.CapitalIncreasePresenter,
CajaMaynas.CreditRequestMonitoringPresenter, CajaMaynas.ConfirmOwnTransferPresenter, CajaMaynas.ConfirmOtherTransferPresenter, CajaMaynas.FingerprintSettingsPre
senter, CajaMaynas.OwnTransfersInteractor, CajaMaynas.SelectCreditAccountCancelInteractor, CajaMaynas.NotificationServicePresenter, CajaMaynas.ProductsForYouInter
actor, CajaMaynas.ThirdPartyCreditsDetailsPresenter, CajaMaynas.TokenDigitalPresenter, CajaMaynas.DPFAccountCancellationInteractor, CajaMaynas.SchedulePaymentDeta
ilsPresenter, CajaMaynas.DetailsOtherBankTransferInteractor, CajaMaynas.DetailsIncreaseCapitalPresenter, CajaMaynas.CodeCardSettingBlockingPresenter, CajaMaynas.C
laimsTrackingPresenter, CajaMaynas.OtherAccountTransferInteractor, CajaMaynas.CTSAccountInteractor, CajaMaynas.FixedTermAccountInteractor, CajaMaynas.GetKeyInter
actor, CajaMaynas.ServicePaymentDetailsPresenter, CajaMaynas.AffiliationTokenDigitalPresenter, CajaMaynas.BasicCodeCardKeyPresenter, CajaMaynas.ServicePaymentInter
actor, CajaMaynas.IncreaseCapitalPresenter, CajaMaynas.DPFAccountCancellationPresenter, CajaMaynas.DetailsOtherBankConfirmPresenter, CajaMaynas.ConfirmInsuranceCa
ncellationPresenter, CajaMaynas.OpeningAccountPresenter, CajaMaynas.OperationTransferMoneyPresenter, CajaMaynas.DetailsOwnCreditPresenter, CajaMaynas.ThirdPartyCr
editsInteractor, CajaMaynas.PersonalInformationUpdateInteractor, CajaMaynas.ConfirmServicePaymentPresenter, CajaMaynas.ThirdPartyCreditsDetailsInteractor, CajaMay
as.ThirdPropertyRenewalInteractor, CajaMaynas.SeeCardDataPresenter, CajaMaynas.CardSettingBlockingPresenter, CajaMaynas.ServicePaymentDetailsInteractor, CajaMayn
as.ClaimsTrackingInteractor, CajaMaynas.DetailsOtherBankConfirmInteractor, CajaMaynas.ThirdPropertyRenewalDetailsPresenter, CajaMaynas.FixedTermAccountPresenter,
CajaMaynas.PersonalInformationUpdatePresenter, CajaMaynas.TurnShippingInteractor, CajaMaynas.MoreListPresenter, CajaMaynas.ConsumerCreditInteractor, CajaMaynas.Op
eningAccountInteractor, CajaMaynas.JoinDigitalBankingPresenter, CajaMaynas.ThirdPartyCreditsPresenter, CajaMaynas.InsuranceAccountCancellationPresenter, CajaMayna
.SelectInsuranceAccountCancelPresenter, CajaMaynas.ConfirmIncreaseCapitalPresenter, CajaMaynas.PayCreditsPresenter, CajaMaynas.ConfirmDPFCancellationPresenter, C
ajaMaynas.TokenInteractor, CajaMaynas.DetailsOtherTransferPresenter, CajaMaynas.ConfirmThirdPartyCreditsPresenter, CajaMaynas.MyInsuranceInteractor, CajaMaynas.Co
nfirmationOverseasUsePresenter, CajaMaynas.ConfirmCancellationInteractor, CajaMaynas.OpeningAccountDetailsPresenter, CajaMaynas.IncreaseCapitalInteractor, CajaMay
as.TurnShippingPresenter, CajaMaynas.DreamAccountPresenter, CajaMaynas.DetailsOtherBankTransferPresenter, CajaMaynas.DetailsAccountPresenter, CajaMaynas.ChangeMe
PasswordInteractor, CajaMaynas.TwoFactorVerificationInteractor, CajaMaynas.ThirdPropertyRenewalPresenter, CajaMaynas.CreditPrendiarioPresenter, CajaMaynas.DreamA
ccountInteractor, CajaMaynas.DetailsOtherTransferInteractor, CajaMaynas.MyProductsPresenter, CajaMaynas.ConfirmPersonalInformationUpdateInteractor, CajaMaynas.Hom
ePresenter, CajaMaynas.DisaffiliationAutomaticDebitInteractor, CajaMaynas.ProductsForYouPresenter, CajaMaynas.SelectDPFAccountCancelInteractor, CajaMaynas.Confirm
TurnShippingInteractor, CajaMaynas.ConfirmPersonalInformationUpdatePresenter, CajaMaynas.ConfirmIncreaseCapitalInteractor, CajaMaynas.FingerprintSettingsInterac
tor, CajaMaynas.TwoFactorVerificationPresenter, CajaMaynas.ConfirmOnlineShoppingPresenter, CajaMaynas.ConfirmInsuranceCancellationInteractor, CajaMaynas.Operation
istInteractor, CajaMaynas.ConfirmationLimitSettingPresenter, CajaMaynas.MicroInsuranceAffiliationInteractor, CajaMaynas.CodeCardSettingBlockingInteractor, CajaMa
ynas.CreditKapilashInteractor, CajaMaynas.RegisterFrequentOperationInteractor, CajaMaynas.CardBlockingPresenter, CajaMaynas.MoneyOrdersPresenter, CajaMaynas.Conf
irmCreditCancellationPresenter, CajaMaynas.PledgeRetentionInteractor, CajaMaynas.LimitSettingsPresenter, CajaMaynas.AffiliationTokenDigitalInteractor, CajaMaynas
.ServicePaymentPresenter, CajaMaynas.OwnTransfersPresenter, CajaMaynas.ConstantListInteractor, CajaMaynas.AutomaticDebitAffiliationPresenter, CajaMaynas.ConfirmOwn
TransferInteractor, CajaMaynas.CreditRequestMonitoringInteractor, CajaMaynas.OtherBanksTransferPresenter, CajaMaynas.ConfirmCancellationInteractor, CajaMaynas.Token
Presenter, CajaMaynas.JoinDigitalBankingInteractor, CajaMaynas.AmountValidator, CajaMaynas.CreditAccountCancellationInteractor, CajaMaynas.ConfirmThirdPropertyRe
newalPresenter, CajaMaynas.ThirdPropertyRenewalInteractor, CajaMaynas.DetailsOtherBankTransferPresenter, CajaMaynas.DetailsOtherBankConfirmPresenter, CajaMaynas

```

Evidencia de la exposición de datos sensibles a través de propiedades de accesibilidad - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 83 de 132

Evidencia

```

/ _ | Frida 16.7.0 - A world-class dynamic instrumentation toolkit
| (| |
> _ | Commands:
/_/ |_ | help      -> Displays the help system
. . . . object?   -> Display information about 'object'
. . . . exit/quit -> Exit
. . . .
. . . . More info at https://frida.re/docs/home/
. . . .
. . . . Connected to iPhone (id=4fcd718b36cae23ab983574f84a96ff059f4a243)

[iPhone::CajaMaynas ]-> console.log(ObjC.classes.MCKeychain.$methods);
setAccessibilityLabel:
setAccessibilityTraits:
setAccessibilityHint:
setAccessibilityValue:

[iPhone::CajaMaynas ]-> Application requested
[iPhone::CajaMaynas ]->

```

Evidencia de la exposición de datos sensibles a través de propiedades de accesibilidad - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 84 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.4
Subpuntuación de Impacto	2.7
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.4

5.21. Formulario susceptible ante ataques recurrentes

Formulario susceptible ante ataques recurrentes		RIESGO MEDIO	
		CVSS	5.3
Descripción	Como parte de las pruebas realizadas, se han identificado formularios web sin controles de seguridad que permiten que un eventual atacante ingrese información de manera automatizada pudiendo generar indisponibilidad del servicio a través de la saturación del mismo o ingresando información innecesaria en la Base de Datos.		
ACTIVOS DE INFORMACIÓN AFECTADOS			
N°	Aplicación Móvil	Sistema Operativo	Proceso
1	Banca Móvil	Android / iOS	Login Olvide mi Contraseña Envío de token SMS
ESCENARIOS DE EXPLOTACIÓN			
- Un cibercriminal puede obtener una lista de usuarios de la organización utilizando técnicas de OSINT para realizar ataques recurrentes de diccionario al formulario web de inicio de sesión, con la finalidad de: • Obtener acceso al sistema con una de las credenciales ingresadas. • Generar la indisponibilidad del servidor que soporte al sistema. • Realizar un envío masivo de SMS.			
RIESGO DE LA VULNERABILIDAD			
- Posible pérdida de la disponibilidad del sistema.			
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)			
<u>Mecanismo de identificación:</u> 1. Identificación de formularios web sin controles de seguridad. En este caso se identificó que el formulario de acceso al sistema de información es susceptible a ataques recurrentes de acceso NO autorizado. 2. Utilización de herramientas y/o scripts automatizados para el ingreso masivo de información. 3. Saturación del servicio web y/o de la Base de Datos que soporta el sistema de información ocasionando una denegación de servicio (DoS).			
CONSECUENCIAS			
- Denegación de Servicio (DoS) de los servidores que contengan formularios web sin mecanismos de seguridad. - Calidad de la información de las Bases de Datos afectada por el ingreso de datos no reales. - Pérdida de horas hombre por la paralización de actividades que dependen de la disponibilidad del sistema.			
REMEDIACIÓN			
Se recomienda implementar controles del tipo CAPTCHA en todos los formularios. El control del tipo CAPTCHA debe cumplir con las siguientes características:			

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 86 de 132

A. Implementar librería NoCaptcha reCAPTCHA de Google

La compañía Google ha realizado una librería llamada NoCaptcha, la misma que implementa un control ante ataques recurrentes de acceso por medio de robots, herramientas o scripts. La implementación de esta librería tiene como principal ventaja que no requiere que el usuario llene información asociada a números y/o letras de imágenes captcha, sino que basta dar un clic sobre una caja de texto para validar que no se trata de herramientas automatizadas.

Se recomienda evaluar la viabilidad de implementar la librería NoCaptcha de Google sobre los portales evaluados.

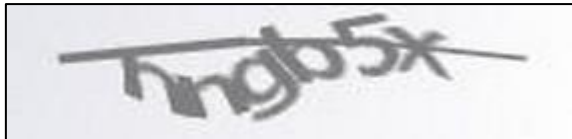
Se adjunta la dirección URL del proyecto en mención recomendado:
<https://www.google.com/recaptcha/intro/index.html>

B. Implementar librería propia de imagen Captcha

En caso se decida implementar una librería de desarrollo propio para los portales web evaluados y que implemente números o letras para que puedan ser llenados por el usuario de la aplicación, se recomienda que la imagen CAPTCHA implementada cumpla con los siguientes requerimientos:

- La imagen captcha aparezca en todos los intentos de acceso al sistema.
- La imagen captcha cuente con las siguientes características técnicas para dificultar su obtención mediante programas OCR:
- Caracteres alfanuméricos (letras + números)
- Caracteres con grados de inclinación
- Fondo del lienzo distorsionado

Características recomendadas a cumplir por el control "CAPTCHA"



Evidencia

Request

Raw Params Headers Hex

```
POST /api/v1/WebBanca/Token/GuardarSMS HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
Content-Length: 114
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0

{"cDescripcion":"2","cID":"1094800027014","cID_Dispositivo":"duqwOz1zREamPFLusI41kX","cOperacion":"2","nEstado":1}
```

Evidencia de formulario susceptible ante ataques recurrentes - Android

Evidencia



Número de tarjeta
4697100201159410

Clave web
.....

☐ Recordar datos



Evidencia de formulario susceptible ante ataques recurrentes - Android

Evidencia

1	1	200	☐	0	☐	271
2	2	200	☐	0	☐	271
3	3	200	☐	0	☐	367
4	4	200	☐	0	☐	271
5	5	200	☐	0	☐	271
6	6	200	☐	0	☐	271
7	7	200	☐	0	☐	271
8	8	200	☐	0	☐	271
9	9	200	☐	0	☐	271

RequestResponse

RawParamsHeadersHex

```
POST /api/v1/WebBanca/Auth/ValidaIngreso HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
Content-Length: 246
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0

{"cContrasena":"2d1300bd6db839bb2b814f8825910d8730d170a966f79c79fcffd0977f5dd2701f27a5ca3a28e30dec2be2085c2917029df5846cabadc1b0ffc0c6805236b2ed","cIdDisp":"duqwOz1zREamPFLusI4lkX","cNumtarjeta":"4697100201159418","nTipoCanal":1,"nTipoTarjeta":1}
```

Evidencia de formulario susceptible ante ataques recurrentes - Android

Evidencia

1	1	200	☐	0	☐	271
2	2	200	☐	0	☐	271
3	3	200	☐	0	☐	367
4	4	200	☐	0	☐	271
5	5	200	☐	0	☐	271
6	6	200	☐	0	☐	271
7	7	200	☐	0	☐	271
8	8	200	☐	0	☐	271
9	9	200	☐	0	☐	271

RequestResponse

RawHeadersHex

```
HTTP/1.1 200 OK
Content-Length: 98
Connection: close
Content-Type: application/json
Date: Tue, 25 Mar 2025 20:04:29 GMT
Server: Kestrel
api-supported-versions: 1.0

{"nResultado":3,"cDescResultado":"No se pudo verificar los datos ingresados","cValorResultado":""}
```

Evidencia de formulario susceptible ante ataques recurrentes - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 89 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.3
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.3

5.22. Envío de información sensible en texto claro

Envío de información sensible en texto claro		RIESGO MEDIO							
		CVSS	5.3						
Descripción	Durante el desarrollo de las pruebas de Ethical Hacking sobre los sistemas de información de la organización, se realizó un análisis del tráfico de la información que transfieren los sistemas de información para verificar que estas viajan de forma segura mediante el envío de información sensible a través de la red.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un eventual atacante podría obtener credenciales de acceso e información sensible mediante una inspección de tráfico en la red (<i>Sniffing</i>) e ingresar al sistema y modificar y/o eliminar información sensible del mismo. - Ataques del tipo “sesión hijacking” (secuestro de sesión) a través de la obtención de cookie.									
RIESGO DE LA VULNERABILIDAD									
- Pérdida de la confidencialidad de la información personal del colaborador. - Posible pérdida de la integridad de la información personal del colaborador.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> Mediante este análisis fue posible identificar que el envío de credenciales de acceso e información sensible a los sistemas de información está viajando a través de la red sin mecanismos de cifrado, es decir, el usuario y contraseña e información sensible de acceso viajan en texto claro ante lo cual un eventual atacante podría obtener dichas credenciales e información sensible de acceso mediante una inspección de tráfico en la red (<i>Sniffing</i>) y obtener acceso a los sistemas de información y obtener dicha información sensible. Estas credenciales viajan sin cifrar por la red debido a que hacen uso del protocolo HTTP que es un protocolo débil y no cuenta con mecanismos de cifrado para la protección de las credenciales de acceso e información adicional del sistema web de la organización.									
CONSECUENCIAS									
- Ingreso al sistema sin autorización, comprometiendo la confidencial e integridad de la información personal de los colaboradores de la organización. - Manipulación del sistema para beneficiarse o beneficiar a un grupo de personas con las gestiones o aprobaciones que se realizan a través del sistema.									
REMEDIACIÓN									
1. Se recomienda implementar mecanismos de cifrado bajo el protocolo HTTP + SSL (HTTPS) en el portal web y no sólo sobre los formularios de envío de credenciales, esto garantiza que									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 91 de 132

toda la información se envíe cifrada y se evitan ataques del tipo “sesión hijacking” (secuestro de sesión) a través de la obtención de cookies.

INTERNOS

- Debido a que los sistemas de información son INTERNOS, se podría hacer uso de certificados digitales AUTOFIRMADOS, es decir, certificados firmados por el mismo servidor en donde se generan los mismos. Es importante mencionar que en caso fuesen servidores web expuestos a INTERNET se requeriría de certificados digitales emitidos por una AUTORIDAD CERTIFICADORA (CA) reconocida por los navegadores de internet.

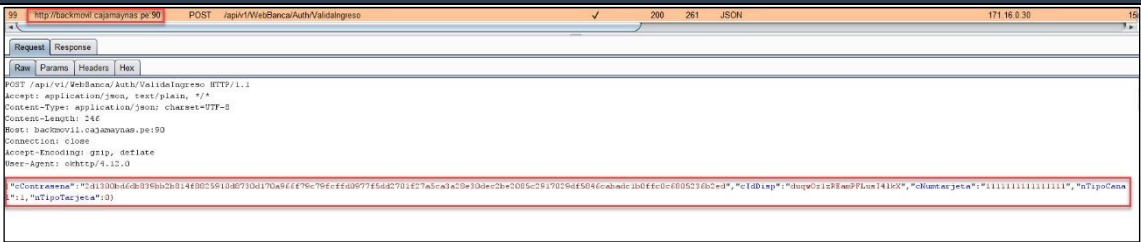
EXTERNOS

Esta implementación debe considerar lo siguiente:

- Certificados digitales emitidos por una entidad reconocida internacionalmente: [Godaddy](#), [VeriSign](#), etc.

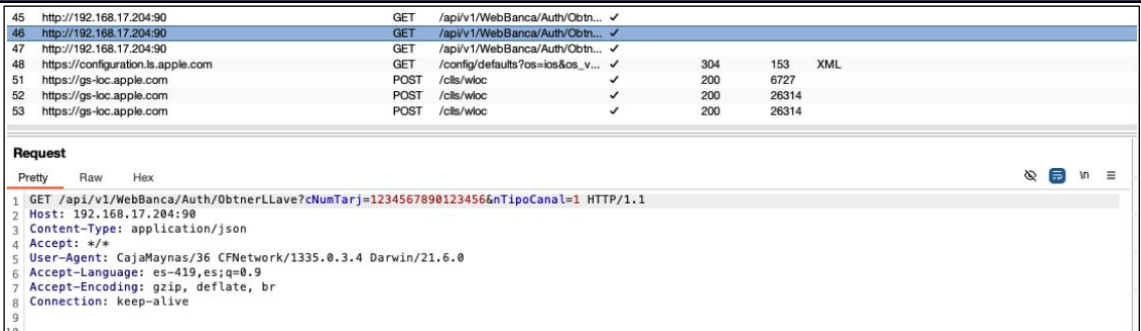
- Se debe hacer uso del protocolo TLS1.1, TLS1.2 y/o TLS1.3

Evidencia



Evidencia de envío de credenciales sin mecanismo de cifrado - Android

Evidencia



Evidencia de envío de credenciales sin mecanismo de cifrado - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 92 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Requerido
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.3
Subpuntuación de Impacto	3.6
Subpuntuación de Explotabilidad	1.6
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.3

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO BANCA MÓVIL	Fecha: 02/04/2025 Página: 93 de 132

5.23. Configuración inadecuada en la comunicación

Configuración inadecuada en la comunicación		RIESGO MEDIO							
		CVSS	5.3						
Descripción	Toda aplicación móvil con salida al exterior del dispositivo móvil hace uso de canales de comunicación con servidores donde se alojan aplicaciones web o similares. Esta comunicación debe ser segura evitando interceptaciones por parte de entidades ajenas a los involucrados. En los sistemas operativos del teléfono móvil como Android se tiene una configuración en AndroidManifest.xml donde se puede indicar si se permite la comunicación en texto claro. Si bien a pesar de tener esta configuración, internamente en el código de la programación se evita que ocurra el hombre en el medio a través de mecanismos de protección más avanzados como el certificate pinning, se considera como una mala configuración el tener habilitada la comunicación en texto claro.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android							
ESCENARIOS DE EXPLOTACIÓN									
- Si la aplicación <i>no</i> implementa correctamente Certificate Pinning, y la configuración en AndroidManifest.xml permite tráfico en texto claro, un atacante en la misma red (Wi-Fi pública, red local comprometida) podría interceptar la comunicación entre la aplicación y el servidor. Al permitirse el tráfico no cifrado, el atacante podría leer y potencialmente modificar los datos transmitidos.									
RIESGO DE LA VULNERABILIDAD									
- Si la aplicación transmite nombres de usuario y contraseñas sin cifrado TLS un atacante podría capturarlos. - Un atacante podría modificar los datos transmitidos antes de que lleguen al servidor o a la aplicación, lo que podría llevar a acciones no deseadas o corrupción de datos.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Revisión de Android Manifest o sus xml asociados en network-security-config 2. Se encontró que la configuración permitía la comunicación en texto claro									
CONSECUENCIAS									
- Pérdida de datos personales y financieros de los usuarios. - Acceso no autorizado a cuentas de usuario - Realización de transacciones fraudulentas.									
REMEDIACIÓN									
1. Se recomienda implementar el mecanismo que evite la interceptación de la comunicación 2. Se cuenta con recomendaciones en la guía del desarrollo de Android los mecanismos para el aseguramiento a. Network Security Configuration https://developer.android.com/privacy-and-security/security-config									

cleartextTrafficPermitted="false"

b. Pinning

<https://developer.android.com/training/articles/security-ssl#Pinning>

Los mecanismos:

- Trust Manager
- OkHttp y CertificatePinner
- Android Pinning Library
- Entre otros

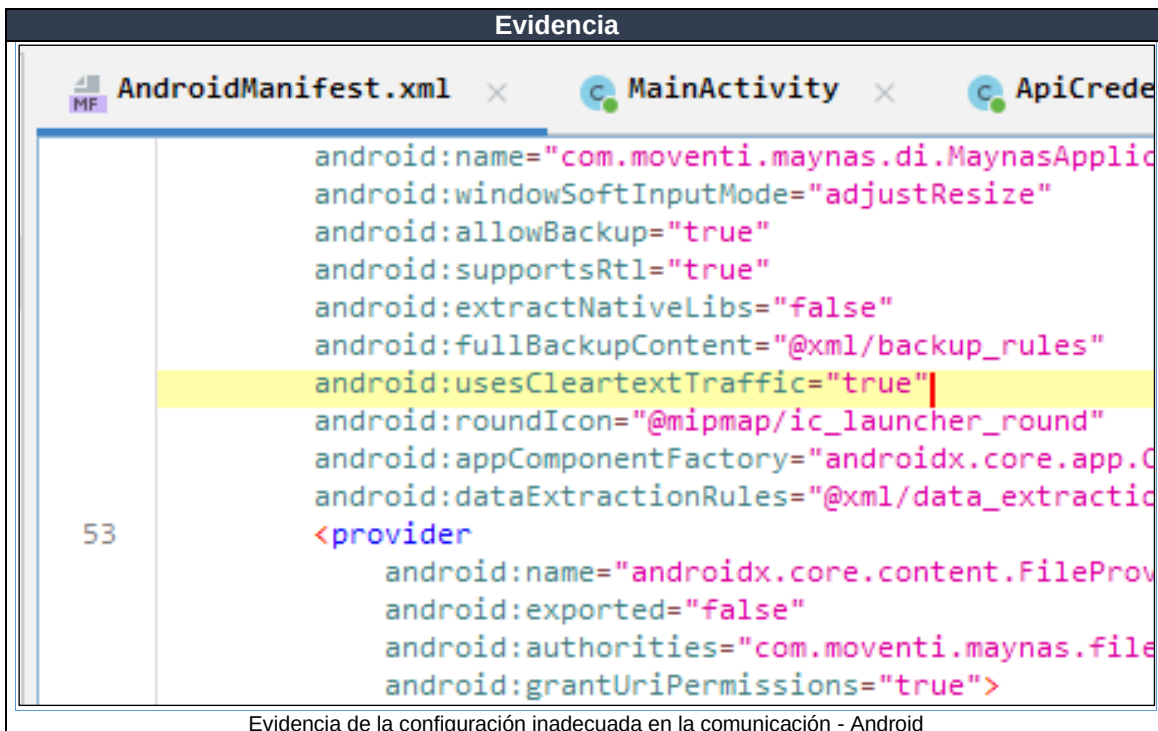
Sirven para implementar certificate pinning y donde se recomienda hacer la implementación para versiones inferiores a Android 9 y de la forma moderna. Esto está explicado en <https://ulvi-jabbarli.medium.com/ssl-pinning-in-android-apps-995f5b9c568>

c. Certificados clientes

<https://developer.android.com/training/articles/security-ssl#ClientCert>

“SSL también admite la noción de certificados de cliente que permiten al servidor validar la identidad de un cliente... las técnicas involucradas son similares a la especificación de un TrustManager personalizado.”

Evidencia



```

android:name="com.moventi.maynas.di.MaynasApplic
android:windowSoftInputMode="adjustResize"
android:allowBackup="true"
android:supportsRtl="true"
android:extractNativeLibs="false"
android:fullBackupContent="@xml/backup_rules"
android:usesCleartextTraffic="true"
android:roundIcon="@mipmap/ic_launcher_round"
android:appComponentFactory="androidx.core.app.C
android:dataExtractionRules="@xml/data_extractio
<provider
    android:name="androidx.core.content.FileProv
    android:exported="false"
    android:authorities="com.moventi.maynas.file
    android:grantUriPermissions="true">

```

53

Evidencia de la configuración inadecuada en la comunicación - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 95 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.3
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.3

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 96 de 132

5.24. Inadecuada protección de información sensible

Inadecuada protección de información sensible		RIESGO MEDIO							
		CVSS	5.3						
Descripción	Cuando se hace referencia a información sensible, hacemos notar que se trata de información confidencial de la infraestructura de la empresa, tipo de servidores usados, información privada de los usuarios o clientes, especificaciones técnicas de la comunicación entre cliente – servidor, entre otros. También nos referimos a los secretos o información que permite comunicarse con servidores o aplicaciones de terceros. En términos generales, la información sensible debe ser resguardada y accedida de manera restringida y con los privilegios necesarios. Sin embargo, hay casos donde se tiene rutas (direcciones o enlaces) expuestas en el código fuente de la aplicación en los cuales se puede observar que las rutas tienen información sensible. O también se puede encontrar secretos que al ser usados de manera externa a la aplicación no se tienen restricciones								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante realiza ingeniería inversa de la aplicación móvil para examinar su código fuente. Si las rutas o secretos sensibles están expuestos en el código, el atacante puede extraerlos fácilmente									
RIESGO DE LA VULNERABILIDAD									
- En caso si almacenase información sensible como contraseñas, credenciales, datos privados, estos podrían ser respaldados y restaurados en otro dispositivo - Esto podría llevar a un mal uso de estos datos para mayores ataques.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Se aplicó la ingeniería de reversa del APK publicado. 2. Se identificó secretos de Google Maps como el API KEY 3. Se hizo un escaneo de varios puntos de acceso para identificar cuáles están no protegidos usando https://github.com/ozguralp/gmapsapiscanner 4. Se identificó que este API Key no está protegido y que podría ser usado por un atacante de manera gratuita haciendo que la empresa incurra en costos no deseados.									
CONSECUENCIAS									
- Se puede exponer información confidencial de la infraestructura de la empresa, datos de usuarios o clientes, y especificaciones técnicas de la comunicación entre cliente y servidor									
REMEDIACIÓN									
Se recomienda en términos generales: Información sensible • Si la ruta se usa para el acceso a servicios web, esta debe estar restringida según credenciales de autenticación y autorización. • No permitir el listado de archivos en el servidor									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 97 de 132

- Ocultar la información acerca de la infraestructura del servidor (apache, php, iis, etc)
- Agregar un token de validación para poder acceder a esas direcciones.
- Restringir la información de la especificación técnica solo a los involucrados en el proceso de desarrollo y no a terceros

Secretos protegidos

- Google ha enunciado una serie recomendaciones para evitar el abuso del consumo de los servicios de las API keys que destacaremos a continuación. Para más información, visitar:
 - <https://cloud.google.com/docs/authentication/api-keys>
 - <https://developers.google.com/maps/api-security-best-practices>

Aseguramiento a nivel del servicio

Como ocurre una comunicación entre el móvil y el servicio, a nivel de servicio se puede asegurar indicando que sólo los accesos provenientes de una aplicación específica pueden acceder a esos servicios. Agregar el nombre del paquete de la aplicación y la huella digital del certificado de firma SHA-1 como medidas de restricción de uso. Con esto se logra que la aplicación desarrollada que usa estos API key sea la única autorizada para aprovechar esos servicios.

Aseguramiento a nivel de la aplicación

Como la aplicación necesita esas llaves desde el móvil, se recomienda encriptar esas API key de tal forma que un atacante no encuentre esas credenciales sin ningún problema o dificultad. Este aseguramiento es complementario al aseguramiento a nivel del servicio el cual tiene que estar restringida de manera correcta. En algunos servicios como Google Maps no es habitual realizar encriptación, sino solo el aseguramiento a nivel del servicio.

Evidencia

Find: maps

```

58         android:exported="false"
        android:authorities="com.moventi.maynas.fileprovider"
        android:grantUriPermissions="true">
        <meta-data
          android:name="android.support.FILE_PROVIDER_PATHS"
          android:resource="@xml/file_paths"/>
53      </provider>
63      <meta-data
        android:name="com.google.android.geo.API_KEY"
        android:value="AIzaSyDaYBljx_aac5dHu6aCn-MNV9nejM4g8G8"/>
66      <meta-data
        android:name="com.google.android.gms.version"
        android:value="@integer/google_play_services_version"/>
70      <activity

```

Evidencia de la inadecuada protección de información sensible - Android

Evidencia

Results

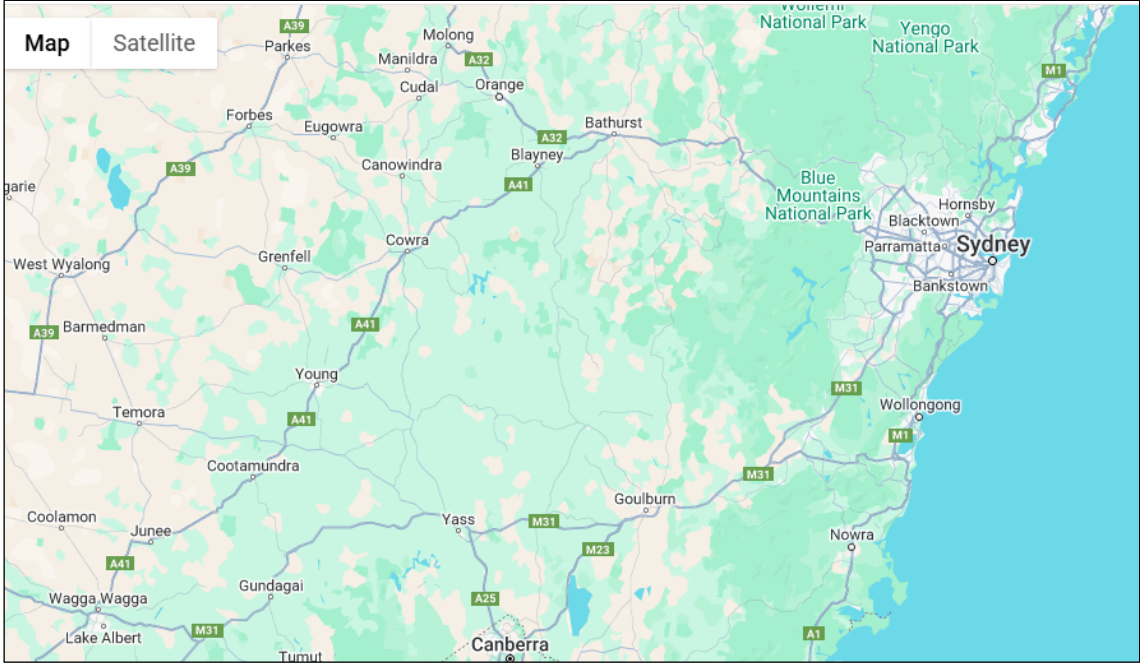
|| Cost Table/Reference to Exploit:

Reference for up-to-date pricing:

<https://cloud.google.com/maps-platform/pricing>
<https://developers.google.com/maps/billing/gmp-billing>

Evidencia de la inadecuada protección de información sensible - Android

Evidencia



Evidencia de la inadecuada protección de información sensible - Android

https://maps.googleapis.com/maps/api/js?key=AlzaSyDaYBljx_aac5dHu6aCn-MNV9nejM4g8G8&callback=initMap&libraries=&v=weekly

Evidencia

```

omargavidia@Omars-MacBook-Air Caja_Maynas % frida -U -l /path/to/your/script.js -f com.cajamaynas.app.2778TZ84C6

usage: frida [options] target
frida: error: [Errno 2] No such file or directory: '/path/to/your/script.js'
omargavidia@Omars-MacBook-Air Caja_Maynas % frida-ps -Uai

```

PID	Name	Identifier
293	AppStore	com.apple.AppStore
71631	CajaMaynas	com.cajamaynas.app.2778TZ84C6

Evidencia de la inadecuada protección de información sensible - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 100 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Bajo
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	5.3
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	3.9
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	5.3

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 101 de 132

5.25. APK instalable en versiones de Android con vulnerabilidades

APK instalable en versiones de Android con vulnerabilidades		RIESGO MEDIO							
		CVSS	4.8						
Descripción	Durante el análisis de vulnerabilidades se identificó que el aplicativo permite instalar en versiones de Android antiguas, las cuales presentan múltiples vulnerabilidades.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante informático podría identificar la vulnerabilidad y tendrá que identificar un cliente con una versión de Android vulnerable y a través de las vulnerabilidades propias del Android llegar a obtener información del aplicativo de la organización.									
RIESGO DE LA VULNERABILIDAD									
- Obtención de información de la aplicación después de explotar una vulnerabilidad propia de Android.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de Identificación:</u> 1. Se aplicó la ingeniería de reversa del apk publicado. 2. Se identifica el archivo AndroidManifest.xml La versión mínima para instalar presenta múltiples vulnerabilidades https://www.cvedetails.com/vulnerability-list/vendor_id-1224/product_id-19997/version_id-545648/opbyp-1/Google-Android-7.0.html https://www.cvedetails.com/vulnerability-list/vendor_id-1224/product_id-19997/version_id-565966/Google-Android-8.1.html									
CONSECUENCIAS									
- Se identificó que permite instalar versiones inferiores a • Android 7, [minSdk=24]									
REMEDIACIÓN									
1. Se recomienda evaluar que el aplicativo sea solo instalable en dispositivos con Android 10.0 (API 29), sin que esto afecte a nivel de negocio (clientes de la empresa) https://developer.android.com/studio/releases/platforms									

Evidencia

AndroidManifest.xml

MainActivity

ApiCred

```

1  <?xml version="1.0" encoding="utf-8"?>
2  <manifest xmlns:android="http://schemas.android.com/apk/
    android:versionCode="43"
    android:versionName="0.43"
    android:compileSdkVersion="34"
    android:compileSdkVersionCodename="14"
    package="com.moventi.maynas"
    platformBuildVersionCode="34"
    platformBuildVersionName="14">
7    <uses-sdk
        android:minSdkVersion="24"
        android:targetSdkVersion="34"/>
11   <uses-permission android:name="android.permission.IN
12   <uses-permission android:name="android.permission.AC
13   <uses-permission android:name="android.permission.AC

```

Evidencia del APK instalable en versión de Android con vulnerabilidades - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 103 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Requerido
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Alto
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	4.8
Subpuntuación de Impacto	3.6
Subpuntuación de Explotabilidad	1.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	4.8

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 104 de 132

5.26. Envío de informacion sensible por el método GET

Envío de informacion sensible por el método GET		RIESGO MEDIO							
		CVSS	4.8						
Descripción	Cuando usas el aplicativo móvil para hacer operaciones, como consultar tu cuenta, detalle de cliente, intentar cambiar la contraseña de la banca móvil, se muestra directamente en la dirección web (URL) el código de persona, número de tarjeta y/o la clave del cajero. En consecuencia, la informacion sensible del usuario queda expuesta a un atacante que este haciendo MiTM en dicha red.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Si un cliente usa la aplicación en una red WiFi publica, un atacante conectado a la misma red podría espiar la conexión y ver la informacion secreta que se enviar sin protección									
RIESGO DE LA VULNERABILIDAD									
- Un eventual atacante podría robar el número de tarjea y la clave de cajero.									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: 1. Se ingreso al sistema 2. Utilizando las diversas funcionalidades se pudo visualizar las siguientes peticiones: <pre>GET /api/v1/WebBanca/Auth/ObtnerLLave?cNumTarj=4697100201159447&nTipoCanal=1 HTTP/1.1 GET /api/v1/WebBanca/Product/ConsultarMisCuentas?cPersCod=1094800027014&nGrupo=2&nTipoCanal=1 HTTP/1.1 GET /api/v1/WebBanca/Auth/DetalleCliente?cPersCod=1094800027014&nTipoCanal=1 HTTP/1.1 GET /api/v1/WebBanca/Auth/VerificarPin?cNumTarjeta=4697100201159447&cClave=0102 HTTP/1.1</pre>									
CONSECUENCIAS									
- Robo de informacion sensible, como posible fraude bancario.									
REMEDIACIÓN									
- Se recomienda enviar este tipo de informacion mediante el método POST. - La aplicación debe usar siempre conexiones seguras (HTTPS) para toda la comunicación entre el aplicativo móvil y el servidor.									

Evidencia

RequestResponse

RawParamsHeadersHex

```
GET /api/v1/WebBanca/Auth/VerificarPin?cNumTarjeta=4697100201159447&cClave=0102 HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0
```

Evidencia del envío de informacion sensible por el método GET - Android

Evidencia

RawParamsHeadersHex

```
GET /api/v1/WebBanca/Product/ConsultarMisCuentas?cPersCod=1094800027014&nGrupo=2&nTipoCanal=1 HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJVc2VyRGFOYSI6IkhNYXluYXNBUEkiLCJyYmYiOiJlE3NDM2OTk3MjcsImV4cCI6MTc0Mzc0NjY2FsaG9zdDoyMDIxLyJ9.ySJK_EUzWFze0JfimXjwFQDCqaYpYxrh36zHAT1lnM
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0
```

Evidencia del envío de informacion sensible por el método GET - Android

Evidencia

RawParamsHeadersHex

```
GET /api/v1/WebBanca/Auth/DetalleCliente?cPersCod=1094800027014&nTipoCanal=1 HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJVc2VyRGFOYSI6IkhNYXluYXNBUEkiLCJyYmYiOiJlE3NDM2OTk3MjcsImV4cCI6MTc0Mzc0NjY2FsaG9zdDoyMDIxLyJ9.ySJK_EUzWFze0JfimXjwFQDCqaYpYxrh36zHAT1lnM
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0
```

Evidencia del envío de informacion sensible por el método GET - Android

Evidencia

45	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/Obtn...	✓			
46	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/Obtn...	✓			
47	http://192.168.17.204:90	GET	/api/v1/WebBanca/Auth/Obtn...	✓			
48	https://configuration.ls.apple.com	GET	/config/defaults?os=ios&os_v...	✓	304	153	XML
51	https://gs-loc.apple.com	POST	/cls/wloc	✓	200	6727	
52	https://gs-loc.apple.com	POST	/cls/wloc	✓	200	26314	
53	https://gs-loc.apple.com	POST	/cls/wloc	✓	200	26314	

Request

PrettyRawHex

```
1 GET /api/v1/WebBanca/Auth/ObtnrLLave?cNumTarj=1234567890123456&nTipoCanal=1 HTTP/1.1
2 Host: 192.168.17.204:90
3 Content-Type: application/json
4 Accept: */*
5 User-Agent: CajaMaynas/36 CFNetwork/1335.0.3.4 Darwin/21.6.0
6 Accept-Language: es-419,es;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9
10
```

Evidencia del envío de informacion sensible por el método GET - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 106 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	4.8
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	4.8

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 107 de 132

5.27. Inadecuada gestión de sesiones: Inicio de sesión en 2 dispositivos móviles de manera simultanea

Inadecuada gestión de sesiones: Inicio de sesión en 2 dispositivos móviles de manera simultanea		RIESGO MEDIO							
		CVSS	4.8						
Descripción	La aplicación del banco permite que una persona use su cuenta desde dos o más teléfonos celulares al mismo tiempo. Esto significa que, si alguien conoce las claves de otra persona, puede usar su cuenta desde su propio teléfono, sin que el dueño de la cuenta se dé cuenta								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante obtiene las claves de acceso de un usuario y las usa para iniciar sesión en su propio teléfono, mientras el usuario legítimo también usa la aplicación en su teléfono									
RIESGO DE LA VULNERABILIDAD									
- El atacante puede realizar transferencias de dinero no autorizadas - El atacante puede acceder a información confidencial de la cuenta bancaria del usuario - Se pueden realizar compras no autorizadas con la cuenta bancaria del usuario									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Se inicio sesión de manera simultánea en 2 dispositivos móviles.									
CONSECUENCIAS									
- Un atacante podría ingresar de manera simultánea a una cuenta para realizar operaciones fraudulentas.									
REMEDIACIÓN									
- Limitar el inicio de sesión a un solo dispositivo a la vez - Implementar un sistema de alertas que notifique al usuario cuando se inicia sesión desde un nuevo dispositivo									



	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 109 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Bajo
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	4.8
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	4.8

5.28. Permisos excesivos del Sistema

Permisos excesivos del Sistema		RIESGO MEDIO							
		CVSS	4.8						
Descripción	Se encontró una irregularidad en la solicitud de permisos que podría ser considerada innecesaria o excesiva. El problema es que tanto <code>NSLocationAlwaysAndWhenInUseUsageDescription</code> como <code>NSLocationWhenInUseUsageDescription</code> tienen descripciones similares que indican que se requiere el acceso a la ubicación "para ubicar la agencia más cercana". Esto podría interpretarse como una sobreexposición de permisos. Aunque la justificación para estos permisos podría ser válida (para localizar la agencia), el hecho de solicitar ambos permisos sin una diferencia clara en su propósito puede generar dudas sobre la necesidad real de cada uno. Esto también podría generar preocupación sobre la privacidad del usuario, ya que más permisos de los necesarios pueden dar acceso a información personal sin una razón clara.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante podría ejecutar la aplicación en un entorno controlado para observar cuándo y cómo se utilizan los permisos de ubicación. Si la aplicación solicita ambos permisos, pero solo utiliza uno de ellos (o los utiliza de manera indistinguible), esto podría confirmar la sospecha de sobreexposición de permisos y ser utilizado como evidencia en informes de privacidad o análisis de seguridad. - Si en el futuro se descubren vulnerabilidades en el manejo de los permisos de ubicación del sistema operativo o en la propia aplicación, el hecho de tener permisos innecesarios concedidos podría ampliar la superficie de ataque y permitir a un atacante acceder a la ubicación del usuario incluso en escenarios donde solo se justificaría un permiso menos intrusivo.									
RIESGO DE LA VULNERABILIDAD									
- Podría dar lugar a un mal manejo de los permisos, donde se comprometen aspectos de la privacidad sin el consentimiento informado adecuado									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> 1. Durante las pruebas estáticas se logró identificar los permisos excesivos del sistema									
CONSECUENCIAS									
- Al solicitar y obtener más permisos de los estrictamente necesarios, la aplicación amplía su acceso a funcionalidades y datos del sistema operativo. Si en el futuro se descubren vulnerabilidades relacionadas con esos permisos, la aplicación podría ser un objetivo más atractivo para los atacantes.									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 111 de 132

REMEDIACIÓN

- Analizar detenidamente por qué la aplicación solicita tanto `CLLocationAlwaysAndWhenInUseUsageDescription` como `CLLocationWhenInUseUsageDescription`. Debe haber una razón clara y distinta para solicitar ambos permisos
- Si la aplicación realmente necesita acceso a la ubicación en diferentes contextos (por ejemplo, seguimiento en segundo plano para ciertas funciones y acceso solo cuando se usa la aplicación para otras), la lógica de solicitud de permisos debe reflejar esto claramente
- Al solicitar cada permiso, proporcionar una explicación concisa y específica de por qué es necesario y cómo se utilizará la ubicación en ese contexto particular. Los mensajes para ambos permisos no deben ser idénticos

Evidencia

```

omargavidia@Omars-MacBook-Air CajaMaynas.app % plutil -p Info.plist | grep -i "NS"

"CFBundleIcons" => {
  "CFBundleIcons~ipad" => {
    "CFBundleShortVersionString" => "1.0"
    "NSFaceIDUsageDescription" => "Autenticación con TouchID o FaceID"
    "NSFileProviderDomainUsageDescription" => "Para ubicar la agencia más cercana"
    "NSLocationAlwaysAndWhenInUseUsageDescription" => "Para ubicar la agencia más cercana"
    "NSLocationWhenInUseUsageDescription" => "Para ubicar la agencia más cercana"
    "NSPhotoLibraryAddUsageDescription" => "This app requires access to the photo library."
    "UIApplicationSceneManifest" => {
      "UIApplicationSupportsMultipleScenes" => 1
      "UISceneConfigurations" => {
        "UIApplicationSupportsIndirectInputEvents" => 1
        "UISupportedInterfaceOrientations" => [
          "UISupportedInterfaceOrientations~ipad" => [

```

Evidencia del acceso excesivo a permisos del sistema - iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 112 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Bajo
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	4.8
Subpuntuación de Impacto	2.5
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	4.8

5.29. Exposición de información innecesaria en el cuerpo del token JWT

Exposición de información innecesaria en el cuerpo del token JWT		RIESGO BAJO							
		CVSS	3.7						
Descripción	La vulnerabilidad radica en la inclusión de información innecesaria y potencialmente sensible, como direcciones IP, dentro del cuerpo de un token JWT. Un token JWT (JSON Web Token) es un estándar para la transmisión segura de información entre partes como un método de autenticación. Sin embargo, cuando se incluyen datos adicionales que no son estrictamente necesarios para la autenticación, se crea una superficie de ataque más amplia.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante podría intentar fijar una sesión al manipular el token JWT para incluir una dirección IP específica, lo que podría permitirle suplantar la identidad de un usuario.									
RIESGO DE LA VULNERABILIDAD									
- La exposición de direcciones IP puede llevar a una pérdida significativa de privacidad para el sistema									
DETALLE EXPLOTACIÓN (Técnica utilizada)									
Mecanismo de identificación: Se accedió a la aplicación web y se identificó que se utiliza el siguiente token <pre>Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJvc2VyRGF0YSI6IkkNNYXluYXNBUEkiLCJmYmYiOiJlE3NDI5MzQyMTQsImV4cCI6MTc0MzAyMDYxNCwiaWF0IjoxNzQyOTM0MjE0LCJpc3MiOiJodHRwOi8vbG9jYWxob3N0OjIwMjE3LWVlYXVkljoiaHR0cDovL2xvY2FsaG9zdDoyMDIxLyJ9.LuMY3wpVp2gBODO1GYQTqNr6SUoQCK7tmvdDAGBbaS4</pre> En la cual se pudo identificar los siguientes parámetros que se encuentran en el cuerpo de este: <pre>"iss": "http://localhost:2021/" "aud": "http://localhost:2021/"</pre>									
CONSECUENCIAS									
- Un atacante podría utilizar la información obtenida de los tokens JWT para robar la identidad de un usuario. - Un atacante podría utilizar la información para lanzar ataques dirigidos contra usuarios o sistemas específicos.									
REMEDIACIÓN									
1. Se recomienda solo incluir información estrictamente necesaria para la autenticación. 2. Si es necesario incluir información sensible en el token, cifrar los datos antes de incluirlos.									

Evidencia de la exposición de información innecesaria en el cuerpo del token JWT - Android

Evidencia

JWT Decoder JWT Encoder

Paste a JWT below that you'd like to decode, validate, and verify.

Generate example

ENCODED VALUE

JSON WEB TOKEN (JWT)

COPY CLEAR

Valid JWT

Invalid Signature

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJvc2VyRGF0YSI6IkhNYXluYXNBUeEiLCJ1YmV1OjE3NDI5MzMyNTYsImV4cCI6MTc0MzAyMDA1NiwiYWV0IjoxNzQyOTMzMjU2LjCjpc3MiOiJodHRwOi8vbG99YXRob3N0OjIwMjE1IiwiaHR0cDovL2xvY2FsaG9zdDoyMDIxLyJ9.SMUhIrTsW4ZH1QXk1Jo55_XjIK8ZwqSUK9-iPyFd15

DECODED HEADER

JSON CLAIMS TABLE

COPY ↗

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

DECODED PAYLOAD

JSON CLAIMS TABLE

COPY ↗

```
{
  "UserData": "CMaynasAPI",
  "nbf": 1742933656,
  "exp": 1743020056,
  "iat": 1742933656,
  "iss": "http://localhost:2021/",
  "aud": "http://localhost:2021/"
}
```

JWT SIGNATURE VERIFICATION (OPTIONAL)

Enter the secret used to sign the JWT below:

SECRET

COPY CLEAR

signature verification failed

a-string-secret-at-least-256-bits-long

Encoding Format UTF-8

Evidencia de la exposición de información innecesaria en el cuerpo del token JWT - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 115 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	3.7
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	3.7

5.30. Debilidades en las cabeceras del protocolo HTTP

Debilidades en las cabeceras del protocolo HTTP		RIESGO BAJO							
		CVSS	3.7						
Descripción	Como parte de la evaluación realizada, se efectuaron revisiones a nivel de los controles de seguridad que deben ser implementadas sobre las cabeceras del protocolo HTTP.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Aplicación Móvil</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>Android / iOS</td></tr></table>				Nº	Aplicación Móvil	Sistema Operativo	1	Banca Móvil	Android / iOS
Nº	Aplicación Móvil	Sistema Operativo							
1	Banca Móvil	Android / iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante informático identificará el servicio y la versión del servidor web a través de las cabeceras HTTP, posteriormente identificará vulnerabilidades asociadas a dicha versión para realizar ataques informáticos más complejos.									
RIESGO DE LA VULNERABILIDAD									
- Suplantación de portales web, con el cual se podría realizar otros tipos de ataques como phishing. - Identificar la versión exacta del servicio web y/o la versión exacta del lenguaje de programación utilizado para el desarrollo de las aplicaciones web, esta información es utilizada eventualmente para ejecutar exploits funcionales sobre dichas versiones identificadas.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
<u>Mecanismo de identificación:</u> Se identificaron vulnerabilidades en las cabeceras del protocolo HTTP. Se identificó que el servidor no cuenta con controles de seguridad. A continuación, se detallan las vulnerabilidades identificadas: 1. <u>Ausencia de controles de anti – Cross Site Scripting (XSS):</u> Estos ataques consisten en el ingreso de parámetros del tipo JAVASCRIPT de tal manera que los mismos se ejecuten en el navegador del usuario, pudiendo extraer información sensible como las cookies del navegador web y así realizar un secuestro de sesión. Al implementar este control podemos notar en las cabeceras del protocolo HTTP la siguiente estructura: X-XSS-Protection "1; mode=block" 2. <u>Ausencia de controles de secuestro de Click - CLICKJACKING:</u> Estos ataques consisten en añadir el portal web en IFRAMES asociados a un dominio ajeno al de la organización, pudiendo realizar ataques de suplantación del portal original sobre los usuarios finales o clientes de los sistemas de información. Al implementar este control podemos notar en las cabeceras del protocolo HTTP la siguiente estructura: X-Frame-Options SAMEORIGIN									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 117 de 132

3. **Ausencia de controles HSTS – Strict Transport-Security:** Se identificó que el servidor web no tiene controles del tipo HSTS (HTTP Strict Transport Security). El control HTSTS aplica una política de seguridad web establecida para evitar ataques que puedan interceptar comunicaciones, cookies, etc. Según este mecanismo un servidor web declara que los agentes de usuario compatibles (es decir, los navegadores), solamente pueden interactuar con ellos mediante conexiones HTTP seguras (es decir, en HTTP sobre TLS/SSL 1). HSTS es un estándar del IETF y se especifica en el RFC 6797.

La política HSTS1 es comunicada por el servidor al navegador a través de un campo de la cabecera HTTP de respuesta denominado "Strict Transport-Security". La política HSTS especifica un período de tiempo durante el cual el agente de usuario deberá acceder al servidor sólo en forma segura.

CONSECUENCIAS

Se identificó que los servidores no cuentan con los siguientes controles de seguridad.

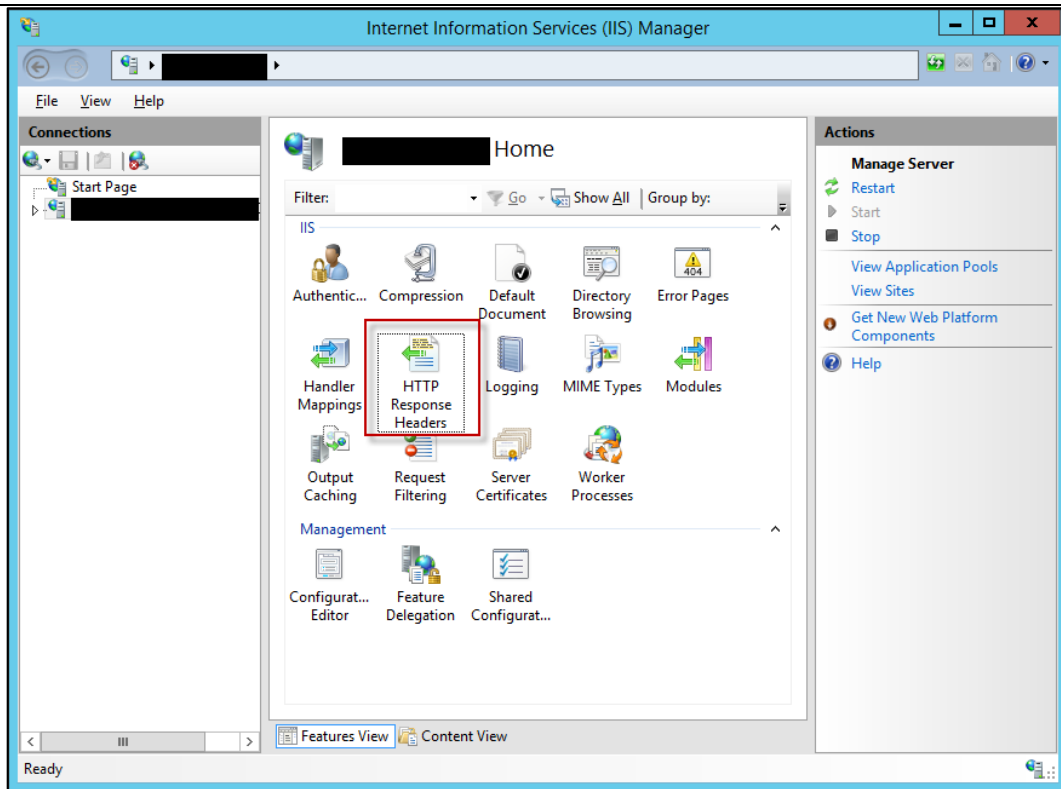
- Ausencia de controles de anti – Cross Site Scripting (XSS)
- Ausencia de controles ANTI-CLICKJACKING
- Ausencia de controles HSTS – Strict Transport-Security
- Exposición de información a través de las cabeceras del protocolo HTTP
- Ausencia de controles de privacidad en hipervínculos – Referer-Policy
- Ausencia de controles de permisos del navegador web – Permissions-Policy
-

REMEDIACIÓN

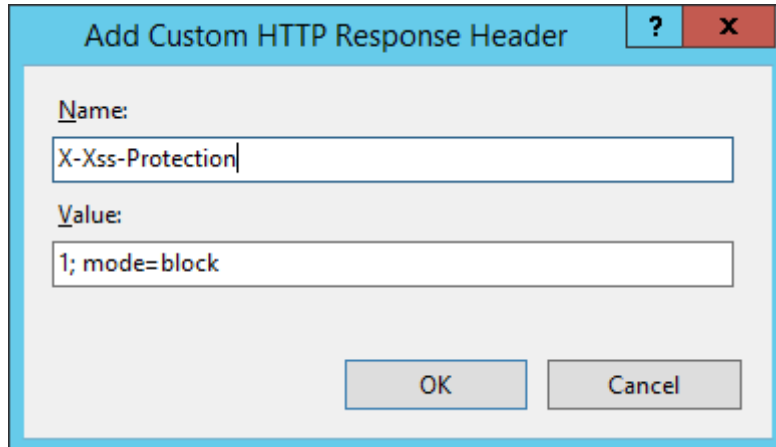
PARA EL CASO DE SERVIDOR IIS:

Se recomienda ocultar la información de las cabeceras del protocolo HTTP de la siguiente manera:

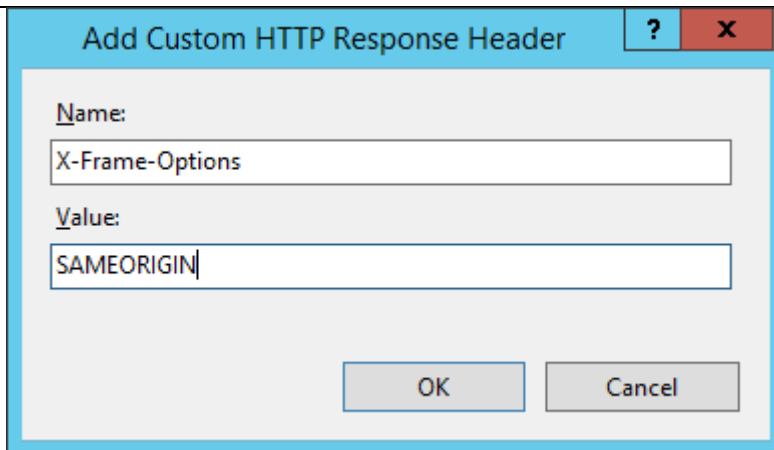
- 1.- Abrir el Administrador de IIS
- 2.- Seleccionar el sitio al que se desea agregar el encabezado
- 3.- Seleccionar "HTTP Response Headers"



1. Para Xss-Protection



2. Para X-Frame-Options



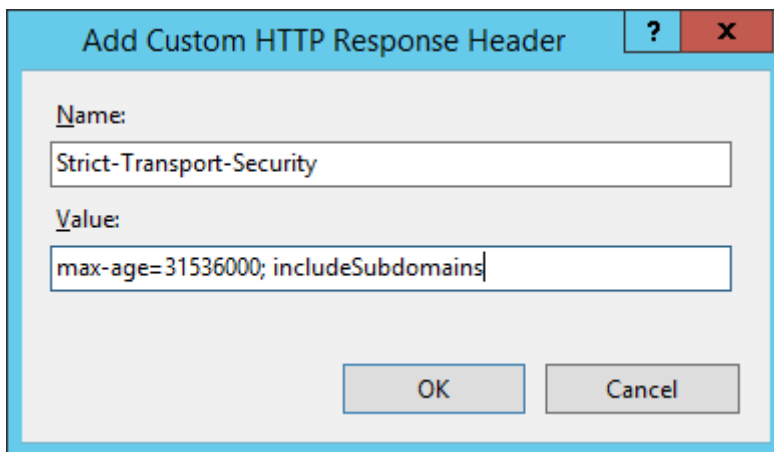
Add Custom HTTP Response Header

Name: X-Frame-Options

Value: SAMEORIGIN

OK Cancel

- Para HTTP Strict Transport Security (HSTS)



Add Custom HTTP Response Header

Name: Strict-Transport-Security

Value: max-age=31536000; includeSubdomains

OK Cancel

- Guardar Cambios.

Remover cabeceras que revelan información sobre el servidor web:

Remover X-AspNet

Abra el archivo Web.Config, busque el nodo <httpRuntime> en <system.web> agregue el atributo enableVersionHeader al nodo httpRuntime y configúrelo en falso.

```
<httpRuntime          maxRequestLength="4096"          targetFramework="4.5"
enableVersionHeader="false"/>
```

Remover X-Powered By

Abra el archivo Web.Config, busque el nodo <httpProtocol> en el nodo <system.webServer>. Compruebe si se trata de un nodo secundario en <httpProtocol> llamado <customHeaders>. De manera predeterminada en MVC, no verá este nodo secundario customHeaders. Si no existe, cree un nodo <cusstomHeaders> y agregue los siguientes incluyen los siguientes para eliminar el encabezado X-Powered-By.

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 120 de 132

```
<httpProtocol>
<customHeaders>
<remove name="X-Powered-By"/>
<remove name="MicrosoftSharePointTeamServices" />
</customHeaders>
</httpProtocol>
```

Remover la cabecera X-AspNet-Version

Abra el archivo Web.Config, busque el nodo <httpRuntime> en <system.web> agregue el atributo enableVersionHeader al nodo httpRuntime y configúrelo en falso.

```
<httpRuntime          maxRequestLength="4096"          targetFramework="4.5"
enableVersionHeader="false"/>
```

Vaciar la cabecera server:

Lamentablemente, realmente no puede eliminar el encabezado server del servidor. Pero puede reescribir su contenido y vaciarlo. En IIS 7+ (IIS 7, 8.5, 8.0, 8.5, IIS 10.0), use una reescritura de outboundRule para eliminar la información de la versión del servidor web de la Server: respuesta del encabezado.

```
<rewrite>
<outboundRules rewriteBeforeCache="true">
<rule name="Remove Server header">
<match serverVariable="RESPONSE_Server" pattern="." />
<action type="Rewrite" value="" />
</rule>
</outboundRules>
</rewrite>
```

PASOS PARA EL CASO DEL SERVIDOR NGINX

1. Habilitar la Cabecera Strict-Transport-Security

El uso de esta cabecera va a impedir que se degrade la navegación a HTTP sin el cifrado correspondiente, obligando por el tiempo definido a que siempre se navegue a través de HTTPS.

Configuración en el Servidor Nginx, agregue la siguiente entrada en nginx.conf bajo el bloque SSL del servidor y reinicie el servidor para verificar los resultados.

```
add_header Strict-Transport-Security 'max-age=31536000; includeSubDomains; preload';
```

2. Habilitar la Cabecera X-Frame-Options.

Se utiliza para proteger a sus visitantes contra ataques de Clickjacking, los cuales consisten en la invocación de un iframe transparente cargado desde un dominio externo en la Web; de este modo, si se superponen falsos botones se puede engañar a la víctima para que realice acciones administrativas sin percatarse de ello (ingeniería social).

Los valores válidos: DENY lo que significa que su sitio no se puede enmarcar, SAMEORIGIN que le permite enmarcar su propio sitio y ALLOW-FROM permite especificar que sitios pueden enmarcar su propio sitio.

Configuración en el Servidor Nginx, agregue lo siguiente en nginx.conf bajo el bloque del servidor y reinicie el servidor para verificar los resultados.

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 121 de 132

```
add_header X-Frame-Options "DENY";
```

3. Habilitar la Cabecera X-XSS-Protection.

Esta cabecera obliga al navegador del usuario a habilitar sus filtros anti XSS, siempre que el navegador sea compatible con esta cabecera.

Los valores válidos: 0, que deshabilita la protección, 1 que habilita la protección y 1; mode=block que le dice al navegador que bloquee la respuesta si detecta un ataque en lugar de desinfectar el script.

Configuración en el Servidor Nginx, agregue lo siguiente en nginx.conf bajo el bloque HTTP y reinicie el servidor para verificar los resultados.

```
add_header X-XSS-Protection "1; mode=block";
```

4. Habilitar la Cabecera X-Content-Type-Options

Esta cabecera sólo tiene un valor válido, nosniff. Ayuda a reducir el riesgo de que se produzca un ataque basado en confusión de tipos mime y la exposición a descargas no autorizadas. En general evita que se carguen hojas de estilo o scripts maliciosos.

Configuración en el Servidor Nginx, agregue lo siguiente en nginx.conf bajo el bloque del servidor y reinicie el servidor para verificar los resultados.

```
add_header X-Content-Type-Options nosniff;
```

Evidencia

1

http://backmovil.cajamaynas.pe:90

GET

/api/v1/WebBanca/Token/GenerarOTP?idDispositivo=duqwOz1zREamPFLusI4lkX

Request

Response

Raw

Params

Headers

Hex

GET /api/v1/WebBanca/Token/GenerarOTP?idDispositivo=duqwOz1zREamPFLusI4lkX HTTP/1.1
Accept: application/json, text/plain, */*
Content-Type: application/json
Host: backmovil.cajamaynas.pe:90
Connection: close
Accept-Encoding: gzip, deflate
User-Agent: okhttp/4.12.0

Evidencia de debilidades en el protocolo HTTP - Android

Evidencia

1

http://backmovil.cajamaynas.pe:90

GET

/api/v1/WebBanca/Token/GenerarOTP?idDispositivo=duqwOz1zREamPFLusI4lkX

✓

200

402

JSON

Request

Response

Raw

Headers

Hex

HTTP/1.1 200 OK
Content-Length: 220
Connection: close
Content-Type: application/json
Date: Fri, 04 Apr 2025 17:11:13 GMT
Server: Kestrel
api-supported-versions: 1.0

({"header":{"nResultado":3,"cDescResultado":"Este dispositivo no se encuentra activado con esta cuenta, ingresa a la app con su numero de tarjeta y clave de instrucciones","cValorResultado":""},"response":[]})

Evidencia de debilidades en el protocolo HTTP - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 123 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	3.7
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	3.7

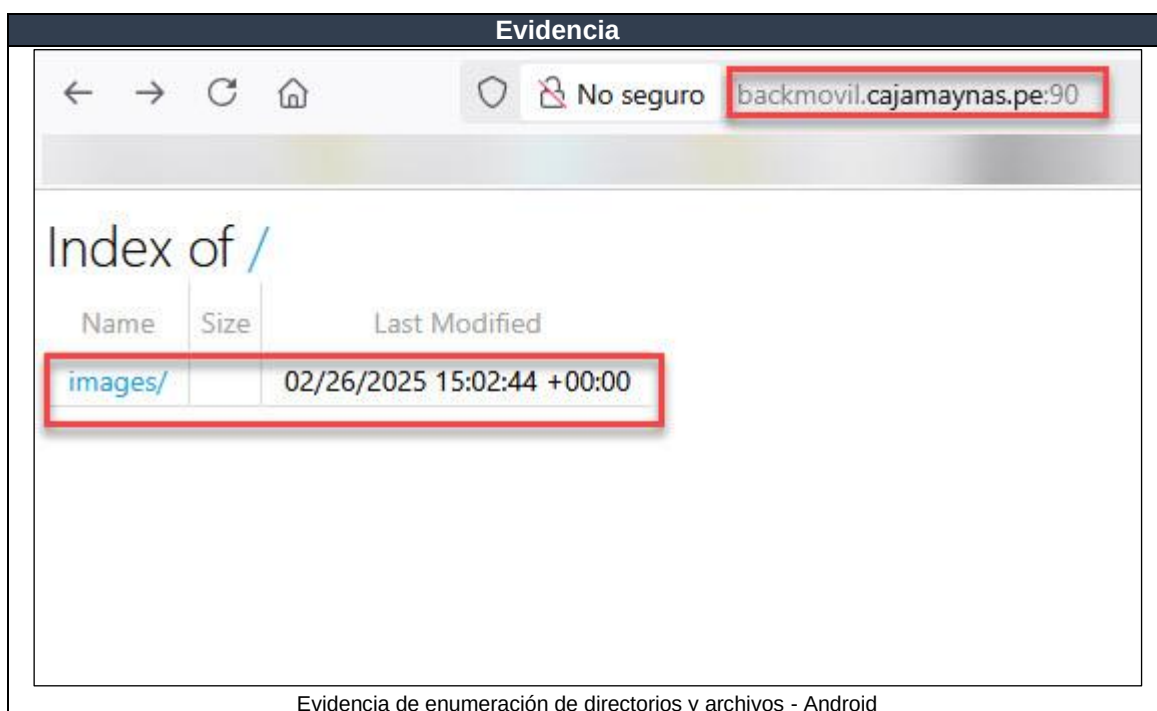
5.31. Enumeración de directorios y archivos

Enumeración de directorios y archivos		RIESGO MEDIO					
		CVSS	5.4				
Descripción	Como parte del análisis realizado se ha podido identificar que una dirección URL tiene activo el listado y enumeración de directorios y archivos, esto permite que cualquier persona pueda navegar por los directorios y encontrar toda clase de archivos importantes e información sensible. La enumeración de archivos y directorios se puede realizar sobre aquellas carpetas que no cuenten con archivos del tipo INDEX.HTML o INDEX.PHP ya que los mismos se ejecutan de manera automática y no permiten realizar la enumeración correspondiente.						
ACTIVOS DE INFORMACIÓN AFECTADOS							
		<table><tr><th>N°</th><th>Direccione URL</th></tr><tr><td>1</td><td>http://backmovil.cajamaynas.pe:90</td></tr></table>		N°	Direccione URL	1	http://backmovil.cajamaynas.pe:90
N°	Direccione URL						
1	http://backmovil.cajamaynas.pe:90						
ESCENARIOS DE EXPLOTACIÓN							
- Un atacante realiza enumeración de directorios y archivos utilizando herramientas automatizadas que generen un ruido mínimo en los equipos de protección perimetral de la organización, los archivos y carpetas expuestos pueden contener desde versiones desactualizadas de plugins hasta exposición de información sensible del propio sistema.							
RIESGO DE LA VULNERABILIDAD							
- Posible pérdida de la confidencialidad de la información.							
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)							
<u>Mecanismo de identificación:</u> 1. Durante el proceso de enumeración de archivos y carpetas, se pudo obtener las siguientes URL's: http://backmovil.cajamaynas.pe:90/ http://backmovil.cajamaynas.pe:90/images/ 2. Se identificó que, a través de dichas URL, es posible realizar la enumeración de carpetas del sistema.							
CONSECUENCIAS							
- Identificación del total de archivos que se encuentran en los directorios del servidor. - Descargar archivos que pueden contener información sensible, por ejemplo: archivos del tipo backup, archivos de configuración.							
REMEDIACIÓN							
<u>En Apache:</u> - Abrir el archivo httpd.conf.							

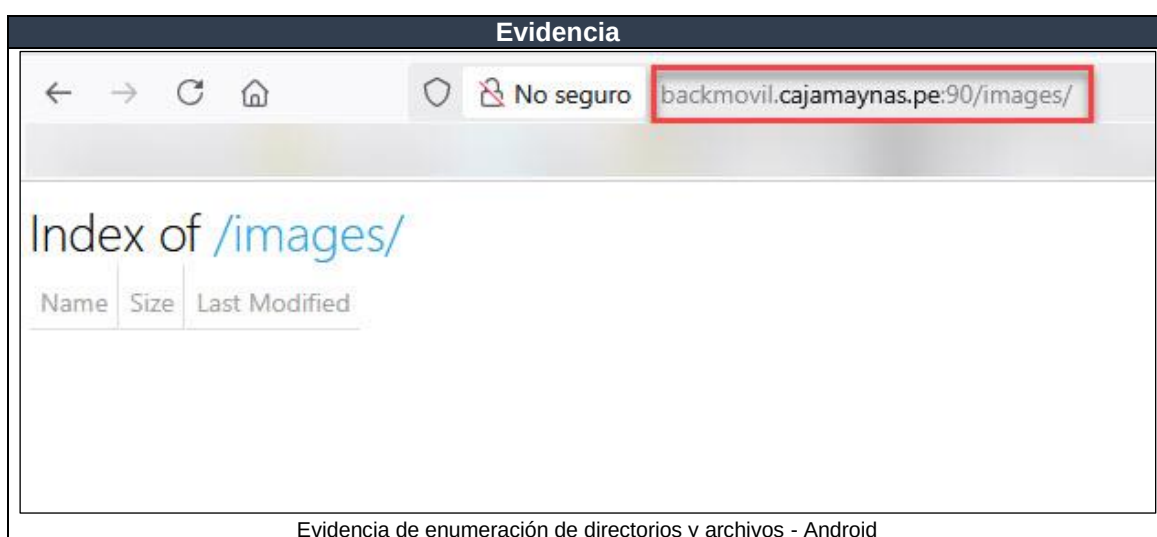
- Busque la directiva "Options" esta directiva se encuentra dentro de un bloque "<Directory>" que define la configuración para un directorio específico
- Elimina la opción "Indexec", esta opción permite la visualización de la lista de archivos y carpetas
- Guarde los cambios y reinicie Apache

Ejemplo

```
<Directory /var/www/html>
    Options -Indexes
</Directory>
```



Evidencia de enumeración de directorios y archivos - Android



Evidencia de enumeración de directorios y archivos - Android

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 126 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring System):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Ninguno
Requiere Interacción del Usuario	Ninguno
Alcance	Sin Cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	3.7
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	2.2
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	3.7

5.32. Posible uso de APIs inseguras en binario

Posible uso de APIs inseguras en binario		RIESGO BAJO							
		CVSS	3.1						
Descripción	El binario puede contener las siguientes API inseguras: <code>_memcpy</code>, <code>_printf</code>, <code>_fopen</code>, <code>_vsprintf</code>, <code>_strlen</code>, <code>_sscanf</code>, <code>_strncpy</code>. Estas funciones se usan comúnmente para diversas tareas, pero si no se usan con cuidado, pueden provocar problemas de seguridad. Advertencia: Las herramientas de análisis de binarios también son propensas a generar falsos positivos. Esto se debe a que estas herramientas analizan el código binario directamente, sin información contextual adicional como el código fuente o la intención del desarrollador.								
ACTIVOS DE INFORMACIÓN AFECTADOS									
<table><tr><th>Nº</th><th>Sistema</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Sistema	Sistema Operativo	1	Banca Móvil	iOS
Nº	Sistema	Sistema Operativo							
1	Banca Móvil	iOS							
ESCENARIOS DE EXPLOTACIÓN									
- Un atacante informático podría identificar el uso de algunos binarios que hacen uso de apis inseguras y hacer uso de éstas de manera no autorizada.									
RIESGO DE LA VULNERABILIDAD									
- Posible pérdida de confidencialidad de la información.									
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)									
Mediante el análisis de vulnerabilidades se logró identificar los siguientes binarios que pueden tener apis inseguras: <code>_memcpy</code>, <code>_fopen</code>, <code>_vsprintf</code>, <code>_strlen</code>, <code>_sscanf</code>, <code>_strncpy</code>. 1. Administración insegura de la memoria: <code>_memcpy</code> y <code>_strncpy</code> se utilizan para copiar memoria. Si el tamaño del búfer de destino no se verifica correctamente antes de copiar, estas funciones pueden desbordar el búfer, sobrescribiendo potencialmente ubicaciones de memoria adyacentes. Esto puede ser aprovechado por atacantes para inyectar código malicioso o alterar el comportamiento del programa. 2. Vulnerabilidades de cadena de formato: <code>_printf</code> y <code>_vsprintf</code> se utilizan para la impresión formateada. Estas funciones toman una cadena de formato y argumentos para insertar. Si se utilizan datos controlados por el usuario dentro de la cadena de formato sin la validación adecuada, un atacante podría inyectar código malicioso que se ejecuta cuando se llama a la función. Esto se conoce como una vulnerabilidad de cadena de formato. 3. Recorrido de ruta de archivo:									

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 128 de 132

_fopen se utiliza para abrir archivos. Si se utilizan datos controlados por el usuario para construir la ruta del archivo sin una validación adecuada, un atacante podría navegar potencialmente fuera de la estructura de directorio prevista y acceder a archivos no autorizados.

4. Desbordamiento de enteros:

_strlen y _sscanf pueden ser vulnerables a desbordamientos de enteros si se utilizan para procesar datos no confiables. Un desbordamiento podría provocar un comportamiento inesperado o fallas, lo que podría permitir a los atacantes obtener el control del programa.

CONSECUENCIAS

- Se identificó el uso posible de apis insegura en binarios.

REMEDIACIÓN

Se recomienda implementar lo siguiente:

Validación de entrada: Siempre valide los datos controlados por el usuario antes de usarlos en cualquiera de estas funciones. Asegúrese de que el tamaño de los datos esté dentro de los límites del búfer previsto para las funciones de copia de memoria y desinfecte cualquier especificador de formato utilizado con _printf y _vsprintf.

Use alternativas más seguras: Considere usar alternativas más seguras como strncpy_s (con verificación de tamaño) o snprintf (con un tamaño de búfer específico) para copiar memoria e impresión formateada. Para operaciones de archivos, use funciones con validación de ruta incorporada.

Revisiones de código: Revise periódicamente el código que utiliza estas funciones para identificar posibles vulnerabilidades y garantizar que la validación adecuada esté implementada.

Evidencia				
NO	ISSUE	SEVERITY	STANDARDS	DESCRIPTION
1	Binary makes use of insecure API(s)	high	CWE: CWE-676: Use of Potentially Dangerous Function OWASP Top 10: M7: Client Code Quality OWASP MASVS: MSTG-CODE-8	The binary may contain the following insecure API(s) _fopen , _memcpy , _scanf , _stat , _strlen , _strcpy , _vsprintf

Evidencia de identificación de apis inseguras en binarios – iOS

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 129 de 132

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	3.1
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	1.6
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	3.1

5.33. Posible uso de función insegura en binario

Posible uso de función insegura en binario		RIESGO BAJO											
		CVSS	3.1										
Descripción	Se logró identificar funciones <code>_malloc</code> en binarios del aplicativo móvil.												
	Ambas funciones se utilizan para reservar memoria en el programa. - <code>_malloc</code> asigna un bloque de memoria del tamaño especificado. - <code>calloc</code> reserva memoria y la inicializa a ceros, lo que puede ser ventajoso en ciertas situaciones.												
	Advertencia: Las herramientas de análisis de binarios también son propensas a generar falsos positivos. Esto se debe a que estas herramientas analizan el código binario directamente, sin información contextual adicional como el código fuente o la intención del desarrollador.												
ACTIVOS DE INFORMACIÓN AFECTADOS													
<table><tr><th>Nº</th><th>Sistema</th><th>Sistema Operativo</th></tr><tr><td>1</td><td>Banca Móvil</td><td>iOS</td></tr></table>				Nº	Sistema	Sistema Operativo	1	Banca Móvil	iOS				
Nº	Sistema	Sistema Operativo											
1	Banca Móvil	iOS											
ESCENARIOS DE EXPLOTACIÓN													
- Un atacante informático podría identificar el uso de una función insegura y así alterar el comportamiento del aplicativo.													
RIESGO DE LA VULNERABILIDAD													
Riesgos potenciales de usar solo <code>_malloc</code>													
- Valores residuales: Si la memoria asignada previamente con <code>_malloc</code> se libera y luego se vuelve a asignar usando <code>_malloc</code> sin inicializarla, podría contener valores residuales de su uso anterior. Esto puede causar errores o problemas de seguridad si esos valores residuales son utilizados de forma inesperada por el programa. - Depuración más difícil: La presencia de valores residuales puede dificultar la depuración de errores, ya que el comportamiento del programa puede depender de datos no inicializados.													
DETALLE DE LA EXPLOTACIÓN (Técnica utilizada)													
Mediante el análisis de vulnerabilidades se logró identificar los siguientes binarios que pueden tener funciones inseguras:													
<code>_malloc</code> ,													
<table><tr><th>NO ↕</th><th>ISSUE ↕</th><th>SEVERITY ↕</th><th>STANDARDS ↕</th><th>DESCRIPTION</th></tr><tr><td>3</td><td>Binary makes use of malloc function</td><td>High</td><td>CWE: CWE-789: Uncontrolled Memory Allocation OWASP Top 10: M7: Client Code Quality OWASP MASVS: MSTG-CODE-8</td><td>The binary may use <code>_malloc</code> function instead of <code>calloc</code></td></tr></table>				NO ↕	ISSUE ↕	SEVERITY ↕	STANDARDS ↕	DESCRIPTION	3	Binary makes use of malloc function	High	CWE: CWE-789: Uncontrolled Memory Allocation OWASP Top 10: M7: Client Code Quality OWASP MASVS: MSTG-CODE-8	The binary may use <code>_malloc</code> function instead of <code>calloc</code>
NO ↕	ISSUE ↕	SEVERITY ↕	STANDARDS ↕	DESCRIPTION									
3	Binary makes use of malloc function	High	CWE: CWE-789: Uncontrolled Memory Allocation OWASP Top 10: M7: Client Code Quality OWASP MASVS: MSTG-CODE-8	The binary may use <code>_malloc</code> function instead of <code>calloc</code>									
CONSECUENCIAS													
- Se logró identificar el posible uso de funciones <code>_malloc</code> en binarios del aplicativo que pueden ser inseguros.													
REMEDIACIÓN													
Para remediar el problema de usar <code>_malloc</code> en lugar de <code>calloc</code> , se pueden tomar las siguientes medidas:													
1. Reemplazar <code>_malloc</code> con <code>calloc</code> :													

	Servicio de Ethical Hacking a los Sistemas de Canales Digitales	Código: EH-CMACMYS- IT
	CAJA MAYNAS	Versión: 2.0
	INFORME TÉCNICO	Fecha: 02/04/2025
	BANCA MÓVIL	Página: 131 de 132

La solución más sencilla es reemplazar todas las llamadas a `_malloc` con `calloc`. Esto asegurará que la memoria asignada se inicialice a cero, lo que puede mejorar la seguridad y la facilidad de depuración.

Evidencia				
3	Binary makes use of malloc function	high	CWE: CWE-789: Uncontrolled Memory Allocation OWASP Top 10: M7: Client Code Quality OWASP MASVS: MSTG-CODE-8	The binary may use _malloc function instead of calloc

Evidencia de identificación de función inseguras en binarios - iOS

Valoración del Riesgo:

A continuación, se muestran los resultados de la valoración del riesgo de seguridad de información basada en el estándar CVSS (Common Vulnerability Scoring Sistema):

Métricas de Puntuación Base	
Métricas de Explotabilidad	
Vector de Acceso	Remoto
Complejidad de Acceso	Alto
Nivel de Privilegio Requerido	Bajo
Requiere Interacción del Usuario	Ninguno
Alcance	Sin cambios
Métricas de Impacto	
Impacto en la confidencialidad	Bajo
Impacto en la integridad	Ninguno
Impacto en la disponibilidad	Ninguno
Métricas de Puntuación Temporal	
Acceso a exploit	No definido
Corrección de vulnerabilidad disponible	No definido
Nivel de confiabilidad de la existencia de vulnerabilidad	No definido

Resultados	
Puntuación Base CVSS	3.1
Subpuntuación de Impacto	1.4
Subpuntuación de Explotabilidad	1.6
Puntuación Temporal CVSS	No definido
Puntuación del Entorno CVSS	No definido
Puntuación Promedio CVSS	3.1